learning-agent

全面深度审查报告

产品、架构、业务正确性、AI 质量、安全、可靠性、体验与工程交付

审查日期：2026-11-02

固定提交：cb62c7aef96be1f15b5206bf2dc600c2cb636d85

范围：main 主分支 · 本地单用户学习工作台 · 只读审查

48 项正式问题 | 19 P1 · 28 P2 · 1 P3

含可复核证据、修复建议、验收条件与分批实施路线

核心判断

保留已有领域架构与业务测试，优先补齐学习证据的一致性、用户内容的保存可靠性，以及外部输入的安全边界。

本报告不包含源码修复；证据包用于复核，反例通过不代表问题已修复。

阅读导航

先读第一节了解结论，再按关注领域查问题。每项均有稳定编号；附录的清单可直接拆成开发任务。

一、总体判断与优先事项 3

二、审查范围、方法与验证基线 5

三、产品定位与整体架构评估 8

四、安全、隐私与依赖供应链 10

五、数据一致性、讲义与 AI 内容来源 17

六、学习评估、知识模型与课程生命周期 22

七、前端交互、可访问性与批注 35

八、工程交付与成熟度建设 46

九、建议修复顺序与退出条件 52

十、验证计划与验收用例设计 54

附录：问题索引、证据与复核说明 56

优先级是本项目的修复排序，不是漏洞扫描器评级。运行复现、静态分析与成熟度建议在正文中分开表述。

报告配套：可编辑 DOCX、固定版 PDF、技术证据 ZIP。源码超链接固定到本次审查提交。

一、总体判断与优先事项

结论：这是一个领域设计认真、业务实现已有厚度的个人学习原型，值得继续迭代；目前尚不足以把“独立掌握、阶段通过、目标达成”当作长期可靠的系统结论。最大缺口是证据、版本和异步状态跨模块传递时不一致。建议先完成本报告的高优先级修复与恢复保障，再扩大真实教材和长期学习数据的使用范围。

审查共收录 48 项正式问题：19 项 P1、28 项 P2、1 项 P3。没有基于本轮证据判定为 P0 的事故。这里的 P1/P2 是面向“本地、单用户、早期个人项目”的修复优先级，不是漏洞扫描器的 CVSS 级别，也不代表 48 项都是同样严重的运行故障。AI-02 及 ENG 系列明确含来源完整性、工程治理建议；其余各条也逐一说明运行复现与静态分析的区别。

优先保护的承诺	已确认的破坏方式	对应问题
一次作答只形成一次证据	同卷并发交卷产生重复作答；中断重试重复计算已完成题。	L01
已撤销或已过期的证据不再支撑通过	题目纠错、改判或目标实质修改后，下游复盘/结课仍沿用旧事实。	L03、L15、L17
用户保存的内容不会静默消失	草稿保存失败被吞掉；过期段落提交、恢复生成和批注刷新可覆盖新内容。	FE-01、DATA-02/03、AN-01
确定判对有可解释的依据	数字前缀解析、仅正数抽样、无出处 authority 标签、公式上下标归一化均存在反例。	L02、L05、L11、AI-01
外部资料不会变成页面代码或越权运算	Markdown 未净化；判分使用完整 mathjs 功能并产生共享状态副作用。	SEC-01、SEC-04
关闭外发与取消任务具有实际效果	关闭语义检索后仍有后续批次；切换解析器后取消发到错误服务。	SEC-03、SEC-07

应该保留的基础

产品目标清楚：先定目标与验收，再组织教材、任务和阶段；掌握分析使用可重算的规则与证据，不以阅读量、聊天量或模型给出的百分比替代独立作答。这些方向与项目实际代码相符。修复应加强现有约束，不应把系统退回到一个只靠提示词维护状态的聊天界面。

依据：docs/PLAN.md:10-57；packages/learner/src/rules.ts:61-131；packages/learner/src/index.ts:77-176

工程上已有真实价值的积累：业务单元和契约分离；SQLite 证据日志有数据库级只追加触发器；改判与撤证可重放；网页抓取有逐跳地址审查；导入有原件保留、失败恢复与体积约束；阶段推进保留用户决策点。现有 427 项通过的测试主要验证这些服务规则，不能因为它们没覆盖全部异步边界就否定其价值。

依据：packages/core/src/migrations.ts；packages/library/src/web/fetch.ts；packages/library/src/imports.ts；packages/curriculum/src/review.ts

不建议现在做的重构

不建议拆微服务、更换 SQLite、引入多租户平台，或为得到漂亮覆盖率而铺满与实现重复的测试。当前问题更适合用少量核心契约解决：不可变提交、带版本的修订、统一有效证据投影、可恢复的文件发布协议、明确的异步资源身份，以及真实 DSH 和浏览器回归。多用户、公网托管、npm 发行属于产品扩大范围时的专项门槛；项目已经明确暂不做，不能据此扣成当前缺陷。

下一轮开发宜先限制新增功能，以“学习证据可信、用户内容不丢、失败可解释可恢复”为主题。优先修复渲染与求值边界、交卷幂等和保存可靠性；随后统一题目/目标/复盘版本，再补长会话、重连和成熟度机制。第九节给出了按依赖排序的实施批次与退出条件。

二、审查范围、方法与验证基线

项目	本次基线
仓库	https://github.com/sagemoyi/learning-agent
固定提交	cb62c7aef96be1f15b5206bf2dc600c2cb636d85
审查分支	main；所有源码引用固定到该提交，避免后续主分支变化改变证据。
提交时间	2026-11-01 17:56:33 UTC（北京时间 2026-11-02 01:56:33）
审查日期	2026-11-02；依赖公告与仓库元数据为当日查询快照。
运行环境	Linux；Node v24.22.1；pnpm 11.25.0；DSH 0.2.0-rc.2；Chromium 153.0.8010.0。
规模	411 个跟踪文件；17 个 packages 目录，其中 14 个业务单元，另有 contracts、kit、app；完整克隆历史 117 个提交、无标签。
数据与修改	只读审查源代码；隔离合成学习库、假模型/假服务。未修改、提交或推送项目源码及锁文件。

阅读顺序包括根及 packages 开发规则、总体计划、开发/试用文档、当前单元设计与研究记录、用户原始取舍记录，以及对应实现和测试。冻结的 history 材料仅作为背景，未拿历史计划冒充当前能力。重点沿“来源→题目→提交→评分→证据→掌握→复盘→目标报告”追踪，并交叉检查文件、SQLite、DSH 会话和前端缓存的生命周期。

实际执行结果

检查	结果	如何解释
安装	pnpm frozen-lockfile 成功；DSH 安装与隔离 profile 安装成功。	锁文件未变化；独立 DSH 依赖图的可复现性另列 ENG-02。
构建/类型	pnpm build 通过；host 与 client 类型检查通过。	类型检查使用 8GiB 堆上限；没有把环境容量限制报为业务缺陷。
现有自动化测试	66 个测试文件通过，1 个跳过；427 项通过，2 项跳过。	两项在线 Voyage 检索基准需要服务凭据，本轮未执行。
覆盖率	语句/行 59.27%；分支 84.96%；函数 92.08%。	V8 报告覆盖 packages/*/src；分母不同，不能互相替代。

检查	结果	如何解释
定向反例	学习域 20 条、核心/讲义 6 条、批注 3 条；另有 BEGIN 故障及安全/前端脚本。	反例断言“通过”表示缺陷发生，并不表示已修复。未把不同脚本的断言强行合成同一测试口径。
真实浏览器	4 种宽度×2 种主题，共 8 组空库 DSH 检查；键盘缺陷已实测。	1440、1024、760、390；390 为触屏模拟。未声称完整学习流程通过。
供应链	根 pnpm 审计与.tools/dsh 实际 npm 依赖树分别扫描。	记录数、独立公告数、受影响节点数分开统计。

最初在受限环境运行测试时，临时 HTTP 服务因 listen EPERM 无法监听，导致相关用例超时。放开本机回环监听后，现有测试全部通过；这类环境失败没有被计为项目缺陷。真实浏览器使用隔离空库和标准 web 安全设置，没有向真实课程植入测试内容，也没有调用真实模型、MinerU、Voyage 或付费搜索接口。

证据强度与优先级

标签	含义
运行复现	在实际函数、真实业务服务/数据库或真实浏览器中观测到反例；明确注明假模型、故障注入和有限 hook 桩。
静态确认	控制流、数据结构或生命周期存在明确缺口，但本轮没有执行对应端到端场景。
产品/成熟度建议	对当前取舍的评价与下一阶段建设建议；不伪装成线上事故。
P0	立即应对的严重事故或无需特殊条件的灾难性影响；本轮未按此级别认定任何项。
P1	会破坏核心证据、内容保存、来源可信或浏览器/求值边界；应在扩大真实使用前修复。
P2	当前可触发但条件较窄、可绕行，或应在稳定迭代中建立的工程保证。
P3	维护、协作和对外发布准备；不阻塞个人本地试用。

本报告是固定版本的深入工程审查，不是“所有可能缺陷均已找到”的证明。没有做真实化工教材的专家盲评、真实模型/手写识别准确率测量、破坏性资源耗尽、实际断电、Windows 完整验收、屏幕阅读器或长期学习效果研究。后续验收方案明确列出了这些尚未验证的事项。

公共仓库 API 在审查日返回：公开、未归档；没有 Release、没有 Actions 工作流；有一个打开的 PR # 2“掌握分析 A——证据有效且可重算”。本报告没有假设该分支已经或即将解决主分支问题，也未修改其状态。主分支已存在相关有效证据逻辑，审查针对的是当前跨模块消费链。开放 PR 应由维护者核实与现状的关系后处理。

依据：仓库 API；PR #2

三、产品定位与整体架构评估

产品承诺应该对应程序不变量

项目最有价值的承诺是让使用者知道自己会什么、证据是什么、何时应再验证。成熟度因此不能只看功能菜单是否齐全。题源是否可证明、题目是否真正新颖、帮助是否入账、错题撤证是否传播、目标变更是否重新验收，都属于产品正确性，而不是可以留到上线后再补的外围功能。

依据：docs/PLAN.md:16-57

业务链	当前合理基础	应补齐的跨界约束
资料→知识→题目	来源、片段、题源分级、知识身份已显式建模。	最终 URL 重新定级；可信标签由证据推导；并发抽取在提交时去重。
题目→交卷→判分	单位、数值、多问、rubric、复核与照片流程较完整。	提交不可变且幂等；问题版本固定；判分不能把有限抽样当证明。
证据→掌握→复盘	learner 规则可重放，帮助/撤证已有语义。	所有报告共享有效证据；保存后的复盘必须随依赖失效。
阶段→结课→目标修订	阶段决策有人确认，目标有版本概念。	状态与必要字段同构；目标语义变化必须改变验收依赖。
编辑→文件→SQLite→通知	文件 hash、变更历史、事务后事件机制已存在。	客户端版本贯穿保存；文件和数据库建立可恢复提交；断线补同步。
任务→设置→取消/重启	任务持久化、失败重试、局部缓存均有实现。	运行所属服务、原始基线、取消信号和成本边界需跟随任务。

模块边界整体合理，数据一致性需要一个共同方案

14 个业务单元、contracts 和 kit 的分工适合当前规模。SQLite 单库、可读 Markdown、DSH 会话分开保存也有实际理由：用户可以在 Obsidian 编辑，业务可结构化查询，会话交给运行时管理。问题不在“存了多种格式”本身，而在相同事实跨这几种载体时缺少统一的版本、失败和恢复协议。DATA-01/02/03/05、L01/09/10/15/17、AN-01 反映了需要共同设计、分别验收的一组一致性缺口。

建议先明确每类事实的唯一拥有者：提交与原始评分由 assess 持有；帮助与作答等事件只追加；有效证据由一个共享投影计算；复盘和报告保存引用的证据版本；文件发布由 core 统一完成；派生链接以 ownerKey 替换。组件或其他插件可以提出命令，但不应借一个陈旧对象回写整条别的事实。

类型契约也需要表达“不可能的组合”。例如 stage 测试必须有阶段蓝图，final 测试必须有目标映射；来源为 authority 必须带可核验凭据；提交状态和答案可见性应独立定义。只把 status 枚举和多个可选字段放在一起，TypeScript 和 Zod 会接受业务上无法完成的对象。L02/L04/L08 正好说明应把这些约束下沉到服务/存储边界，而非只靠老师提示词。

各方面的成熟度判断

维度	判断	最主要依据/缺口
需求与产品边界	基础清楚	本地单用户、化工原理优先和人工决策点明确；需要统一“答对”和“独立验收通过”的含义。
领域架构与可维护性	基础较好，边界待收紧	单元及数据归属清楚；大服务文件和手写协议仍易出现重复事实解释。
核心业务正确性	优先修复	交卷幂等、题源、撤证传播、目标版本和判分均有确定反例。
数据安全与可靠性	优先修复	保存/恢复可覆盖现版；文件与数据库非原子；完整备份恢复未形成操作闭环。
安全与隐私	部分保护扎实，输入边界需修	认证和网页 SSRF 防护存在；renderer、表达式求值、外发停止存在缺口。
AI 与教学质量	需实测校准	可解释规则优于自由模型评分；真实题集、判分误判率、帮助识别和学习效果尚无本轮证据。
界面与交互	空库布局可用，异步可靠性不足	8 组真实页面无观测到横溢；草稿、切课、重连、历史和键盘有问题。
性能与规模	有局部约束，长期规模待测	并行生成/缓存已有；PDF 缓存生命周期、全量查询和产物体积需要有预算的测量。
测试与交付	业务测试较强，门禁不足	427 项通过；缺真实 DSH/React 自动回归与持续集成。
维护、文档与治理	内部文档充分，对外入口薄弱	当前设计和取舍记录详尽；许可、发布、支持、升级/回滚与旧 PR 处置需明确。

四、安全、隐私与依赖供应链

本地应用也会处理来自教材、网页、模型和用户输入的内容。这个场景无需假设公网多租户，仍需要限制内容在浏览器、解释器和外部服务中的权力。以下七项分别涉及代码执行边界、来源身份、外发/取消语义和供应链。

已确认的保护需要保留：DSH 在自定义路由之前做 Host/Origin 检查和签名 cookie 认证；网页抓取绑定经过审查的 DNS 地址、每跳重查、限制 30 秒总时限、5 跳和解压后体积；上传和 ZIP 处理有随机文件名、路径检查、大小限制与清理；老师预设没有开放通用 shell/浏览器/文件写工具。不能把“项目源码里没再写一次认证”误报为无认证，也不能把来源重定向误报为已经绕过 SSRF。

依据：packages/library/src/web/fetch.ts；packages/library/src/files.ts；packages/library/src/parser.ts；packages/app/cordis.patch.yml

SEC-01 共享 Markdown 渲染器未净化不可信 HTML，存在存储型 XSS

优先级 P1 · Chromium 运行复现；无害 DOM 标记、无网络外传

问题与根因：将 Markdown 解析当作 HTML 净化；对所有正文直接使用 HTML sink。已核对 DSH 主要 index/webserver 未设置能覆盖此 renderer 的 CSP；媒体预览用的 sandbox CSP 不是主页面 CSP。

影响与边界：浏览器显示恶意模型输出、资料原文或导入内容时可执行同源脚本，读取或改写学习数据、调用应用接口；外部图片也可产生用户未主动触发的联网请求。当前不声称已验证 OS 代码执行或绕过 cookie 的 HttpOnly。

验证/触发条件：运行 audit/security/repro-input-boundaries.mjs。toHtml('<img src=x onerror="document.documentElement.dataset.auditXss=1">') 仍保留 onerror；[example](javascript:alert(1)) 仍保留 javascript: href。载荷仅设置 DOM 标记，无数据外传。 另见 repro-xss-browser.mjs/json：Chromium153 真实 DOM 标记为 executed，未关闭 web security，拦截所有网络且实际 0 网络请求；验证真实 toHtml 和浏览器 HTML sink，未向日常 DSH 课程植入内容。

源码与证据：

- packages/shell/src/client/html.ts:23-61,71-79 Marked 允许原始 HTML，普通链接把任意 href 原样写回，未做 URL scheme allowlist 或 HTML sanitizer。
- packages/shell/src/client/markdown.tsx:150-152,171-198,238-241 正文、讲义块、行内内容和资料 hover 都通过 dangerouslySetInnerHTML 注入 toHtml 输出。
- packages/library/src/web/service.ts:178-187,191-201 text/plain 网络正文与 Exa 副本直接成为 Markdown，可携带 HTML；模型回复、解析文本也是不可信输入。

.tools/dsh/node_modules/@deepseek-ai/dsh-client-connection/lib/index.js:585-593,640-654 当前 DSH 的 API 确有同源检查与签名 cookie 认证；同源 XSS 可以以已登录用户身份使用这些接口，认证本身无法防止。

建议方案：在唯一共享渲染出口对 marked+KaTeX 生成结果执行成熟 sanitizer，显式允许必需的 KaTeX/引用/表格标签属性；去除事件、危险标签与危险 URL scheme。普通图片按产品需求阻断远程自动加载或显式确认。随后增加 nonce/hash CSP 作为纵深防御。不要依赖正则删除 HTML。

验收条件：1. 浏览器回归覆盖 img/onerror、svg/onload、javascript:、实体/换行编码变体、原始 HTML、Exa/text/plain 及 hover 路径。 2. 无任何 DOM 标记被执行，无恶意远程请求；数学公式、引用卡片、表格、折叠引文仍正确显示。 3. 在实际 DSH 页面核对 response CSP 及所有相关渲染入口。

SEC-02 跨域重定向绕过资料网站分级并错误保留权威出处

优先级 P1 · 局部运行复现；具体替身和限制见下

问题与根因：网络地址安全检查与内容来源可信度是不同边界；程序完成了前者但默认后者可随重定向继承。

影响与边界：受信任网站的开放跳转、被修改的下载链接或跨站迁移可把只当线索/被排除站点内容作为二级来源直接加入课程，跳过三级确认，且引用仍显示原站点。不是已验证的内网 SSRF。

验证/触发条件：合成本机服务器：localhost 被指定二级，返回 302 到 127.0.0.1 的正文；最终 URL 的 rate() 为 clue，但 LibraryWeb.add(...,'teacher') 返回 added 并保存 authority=2、原 URL。完整输出见 repro-input-boundaries.jsonl。allowAddress 仅在测试中允许本机。

源码与证据：

packages/library/src/web/service.ts:84-108,137-147,153-164,167-187 只给输入 URL 定级；抓取最终 URL 后未重定级，HTML 分支还丢弃最终 URL，仍保存原 authority 和 origin URL。

packages/library/src/web/fetch.ts:61-74 允许最多 5 次重定向，安全 IP 检查逐跳执行，但来源权威策略不在这一层重评。

建议方案：抓取层返回完整跳转链；对每一跳和最终 URL 重新按网站规则分类，跨来源降低可信级别时重新请求确认或拒绝；存储 requestedUrl、finalUrl、retrievedAt 和有效 authority，出处指向真正提供内容的资源。

验收条件：1. 二级跳线索/blocked 被拒绝，二级跳三级进入确认，二级同域跳转正常。 2. HTML、PDF、readWeb 以及 Exa 回退均有同一来源策略，记录跳转链。

SEC-03 关闭语义检索后当前资料仍继续上传后续批次

优先级 P1 · 局部运行复现；具体替身和限制见下

问题与根因：队列开关和正在运行的上传生命周期未绑定；界面显示 off 只反映当前设置，不反映仍运行的任务。

影响与边界：用户关闭语义检索或撤回服务密钥后，本书尚未上传的片段仍可能继续发送给旧 Voyage 实例并消耗额度；与数据隐私控制的直觉不符。已发出的请求无法撤回，但后续批次应能阻止。

验证/触发条件：audit/security/repro-index-disable.mjs 创建 257 个合成片段。首批 256 启动后关闭设置并 refresh；放行首批后观察第二批 1 个片段的 embed 调用仍发生，enabled=false，同时 state 显示 off。

源码与证据：

packages/library/src/retrieval.ts:71-77,109-139 refresh()仅清空待处理 queue 并置空 embedder，indexSource 使用开始时捕获的 embedder 持续循环；只有整个插件 dispose 会 abort 共享 controller。

packages/library/src/index.ts:119-123 设置/凭据变化触发 refresh，但没有取消当前任务。

建议方案：为当前索引任务建立可替换的 AbortController；禁用、换密钥或换服务时中止在途请求并清空后续批次，逐批重新核对设置 generation；界面明确区分停止中、已停止、已发送。

验收条件：1. 关闭后不得新增任何网络批次；取消信号到达在途请求。 2. 重新开启可从已完成片段恢复，旧配置结果不会覆盖新任务状态。 3. 测试切换开关、删除密钥、替换密钥和插件退出四种场景。

SEC-04 表达式判分执行完整 mathjs 语言而未采用受限计算器边界

优先级 P1 · 局部运行复现；具体替身和限制见下

问题与根因：把数学表达式输入当作纯数值公式，未限制能改变 math 实例或分配大数据结构的函数。

影响与边界：输入可执行矩阵构造和改变共享单位表；放大的矩阵/计算能阻塞服务主线程或耗尽内存。影响本地可用性和判分一致性，不声称 mathjs 能直接访问操作系统。

验证/触发条件：equivalent('sum(ones(100,100))','10000') 返回 true；equivalent('createUnit("auditSyntheticUnit", "2 m")','10000') 返回 undefined，但之后 math.unit(1,'auditSyntheticUnit').toNumber('m')=2，证明副作用已经发生。测试只分配 100x100 小矩阵。

源码与证据：

packages/assess/src/grading.ts:77-98,103-108 直接 parse、compile、evaluate 学生答案，最多 40 轮，无 AST/function allowlist、计算预算或隔离。

packages/assess/src/units.ts:4-6 全局共用 create(all)实例。

packages/assess/src/calculator.ts:9-38,55-75 已有受限计算工具有 AST 和函数白名单，但判分未复用。

packages/assess/src/index.ts:80,313-323 用户作答进入 judgeByRule；2000 字的答案限制无法限制 ones(大数,大数)这类计算成本。

建议方案：给判分单独创建只含所需纯数学功能的实例，复用或专门定义 AST 白名单，禁止 createUnit/import/evaluate/parse、矩阵、范围、赋值和属性访问；限制节点数、嵌套深度与变量数；将运算放到可终止 worker 并设置时限/内存预算。

验收条件：1. 副作用载荷与矩阵/范围/自定义函数在执行前拒绝，单位表不变。 2. 正常代数/化工公式可用；超复杂输入在固定预算内转人工或模型复核，主 UI 仍响应。

SEC-05 开发依赖和独立 DSH 运行时存在已公开漏洞且缺少联合升级门禁

优先级 P2 · 当日依赖扫描；可达性分层评估

问题与根因：主仓库依赖与 DSH 实际运行依赖各自解析；用历史时间截断维持兼容，会同时保留之后公布漏洞的老依赖，没有锁定可复现的已修复运行时基线。

影响与边界：升级成本与已知漏洞积累。Zod 被用于应用入口，需优先处理；Vitest/Vite/tinypool 开发漏洞的前置条件通常是开发服务暴露/原型污染，不代表普通本地产品会被远程无认证利用。DSH 未启用的 MCP/Office 等能力也不能一概视为可达。

验证/触发条件：pnpm audit --json 与 npm audit --json --prefix .tools/dsh；原始结果及部分 GitHub 官方公告元数据已保存。公告日期核对见 advisories-summary.json；部分 API 返回 403，勿将这些项的发布日期当作已独立复核。

源码与证据：

pnpm-lock.yaml:2071,2397,2437,2500 KaTeX0.16.47、Vite7.3.6、Vitest3.2.7、Zod4.6.5 等版本；根 pnpm audit 报告 18 条记录（17 个不同 GHSA）。

scripts/setup-dsh.sh:13-23 DSH 单独 npm install，--before=2026-10-01，安装只按顶层 DSH 版本决定是否跳过；运行时 lock 不属于仓库根锁。

audit/security/pnpm-audit.json:complete file 2 critical、2 high、10 moderate、4 low，critical 来自开发依赖 tinypool 的 prototype-pollution gadget，不能直接等同产品 RCE。

audit/security/dsh-npm-audit.json:complete file DSH 运行时 15 个受影响依赖节点（7high、8moderate），包含传播计数；依赖子集存在 zod、undici、fast-uri、嵌套 fflate 及 MCP client 公告。

建议方案：建立主 workspace+DSH 两份 SBOM/锁定依赖和定期 audit；先升级 Zod 至修复线>=4.6.6 并做相关边界回归，Vitest/mocker 至少达到各公告共同修复线，KaTeX 与 Vite 按兼容性升级；为 DSH 选择经过集成测试的补丁基线，避免自动 audit fix --force。对不可达公告记录理由/复核期限。

验收条件：1. 两套实际安装依赖都有可追溯锁、SBOM、审计报告和例外理由。 2. 当前可达高风险公告全部修复；升级后 typecheck、全量测试、构建和真实 DSH 加载通过。 3. 不要把两个扫描的计数相加当独立漏洞总数。

SEC-06 MinerU 请求重定向递归无上限且每跳重置超时

优先级 P2 · 局部运行复现；具体替身和限制见下

问题与根因：请求级超时没有覆盖整条跳转链，递归调用没有继承剩余预算。

影响与边界：解析端或对象存储错误重定向时导入会无限请求/等待，违背有限超时预期；可导致任务和流量持续消耗。恶意服务是前置条件之一，这里主要是可靠性问题。

验证/触发条件：假 fetch 连续 8 次返回指向自身的 302，第 9 次返回成功；MineruParser.check()最终成功而未限制跳数，见 repro-input-boundaries.jsonl。

源码与证据：

packages/library/src/parser.ts:45-64 每次 request 新建 AbortSignal.timeout，302 时直接递归 request；注释说 follow once 但无 hop 计数或 seen URL 集合。

建议方案：以迭代方式处理重定向，最多 3–5 跳并检测循环，所有跳转共享一个总 deadline；保持跨 origin 不转发凭据，校验目标地址策略；对 307/308 保持方法语义。

验收条件：1. self-loop、two-node-loop、超过上限跳转快速失败；总耗时不超过一个预算；跨 origin 凭据不外泄。

SEC-07 切换解析服务后取消与恢复使用错误的任务所属服务

优先级 P2 · 局部运行复现；具体替身和限制见下

问题与根因：远端任务 ID 的命名空间被忽略，设置可即时切换但任务与服务身份未绑定。

影响与边界：在 A 解析时切换到 B 后取消，会向 B 发送 A 的 remoteId，A 后台任务继续运行/计费；重启恢复也可能查询错误服务，404 重提或同号串读。后两项为源码推导，已实测取消发往错误服务。

验证/触发条件：repro-parser-switch.mjs：status(parser A,job-on-A)后切换 B 并 cancel，捕获到 cancel(parser B,job-on-A)，本地状态却已经 canceled。

源码与证据：

packages/library/src/imports.ts:20-26,96-103,139-175 运行任务捕获开始时的 parser，但 cancel 重新调用 parserNow；持久化任务只有 remoteId，恢复时也用当前 parser。

packages/contracts/src/schema/library.ts:70-90 任务未存解析器 endpoint/profile 身份，无法将 remoteId 限定在所属服务域中。

建议方案：持久化每次任务运行的解析 provider、规范 endpoint、服务任务 ID 及不含密钥的配置版本；在途取消使用开始时实例；恢复按原服务恢复或显式声明迁移/重新提交，不把旧 remoteId 带到新服务。

验收条件：1. A 运行→切 B→取消仍发到 A；重启后按原服务查原任务；不同服务同 remoteId 不会互相影响。 2. 服务已失效时向用户说明远端取消未确认，保留可复核状态。

依赖扫描应按可达性处理

根目录 pnpm 审计产生 18 条记录、17 个不同 GHSA：2 critical、2 high、10 moderate、4 low。独立 DSH 安装的 npm 审计报告 15 个受影响依赖节点，其中 7 high、8 moderate；它包含父包传播节点，不能与根 18 相加为独立漏洞总数。两个 critical 来自开发依赖 tinypool 的原型污染 gadget，不等于发现两个可直接利用的产品远程执行漏洞。完整扫描 JSON 随证据包提供。

依赖/当前版本	公告修复线	本项目处置判断
Zod 4.6.5	⩾4.6.6	业务输入解析可达，优先升级并配合接口输入预算；并未做破坏性内存耗尽验证。
KaTeX 0.16.47	⩾0.18.2	公告依赖既存原型污染；独立于 SEC-01。升级后仍需净化 HTML。
Vitest / mocker 3.2.7	共同覆盖本轮公告至少 4.1.12	开发/测试暴露面，随兼容升级验证，不按公网生产服务假设评估。
tinypool 1.1.1	⩾2.1.2	critical 为已有原型污染下的 gadget；未发现本项目自身给出该前置入口。
Vite 7.3.6	⩾7.3.7	开发服务器/编辑器相关；应用正式构建使用 esbuild。
fast-uri 3.1.8	⩾3.1.9	区分根 peer 链与实际 DSH 运行树，并验证真实调用路径。
DSH 中的 undici、旧 fflate 等	以当日完整 npm 审计为准	对实际启用能力排可达性；library 直接用的 fflate 0.8.3 不在本轮旧副本 ZIP64 公告范围。

修复线来自审查日注册表公告，部分官方 GitHub 公告日期另行核验；部分 API 返回 403，不能声称所有日期和详情均独立核实。Zod 资源耗尽及 KaTeX 原型污染前置条件已由官方公告再次确认。执行升级时应重新查询受支持版本组合，而不是照表无条件跨主版本升级或运行 audit fix --force。

依据：Zod 官方公告；KaTeX 官方公告

SEC-05 与 ENG-02 有关但不重复：前者是已知依赖风险与联合升级门禁；后者是相同顶层 DSH 版本并不能保证相同传递依赖图。建议在一个兼容性更新批次内同时解决，分别验收“漏洞处置结论”和“干净机器可复现安装”。

五、数据一致性、讲义与 AI 内容来源

这组问题关注系统是否保护用户的长期学习资产，以及已有程序检查是否名副其实。用户已经明确选择不逐句调用模型核对讲义；本报告尊重这一取舍。AI-01 要求修正当前声称存在的公式一致性检查，AI-02 只建议让缺来源状态更容易发现，不要求增加逐句模型调用。

DATA-01 文件替换与 SQLite 提交不具备真正的跨资源原子性

优先级 P1 · 已通过注入提交失败复现

问题与根因：数据库事务无法回滚文件系统操作；源码注释声称与数据库原子提交，但实际存在文件已替换、数据库未提交的窗口。没有提交意图日志、崩溃恢复协议或文件/目录 fsync。

影响与边界：遇到磁盘、提交或进程中断故障时，API 可报告失败但文件已经改变，审计日志仍是旧内容；下次读取又可能把系统写入误记成用户外部编辑。用户据失败提示重试会进一步混淆版本。当前复现是可控的 COMMIT 异常注入，未模拟真实硬件断电。

验证/触发条件：audit/root/data-and-textbook.test.ts R01：保存 OLD，注入一次 COMMIT 异常，再写 NEW；操作拒绝后磁盘为 NEW，最新已提交 change.after 仍为 OLD。

源码与证据：

packages/core/src/store.ts:152-180 commitFile 先在事务内写变更和指纹，再 writeFileSync+renameSync；之后外层事务才 COMMIT。

packages/core/src/db.ts:55-70 COMMIT 失败只 ROLLBACK 数据库，不恢复已替换的文件。

建议方案：选择明确的持久化协议：优先把待发布版本及写入意图先持久化于 SQLite，在同一事务记录状态，写临时文件并同步后替换，完成后标记 published；启动时按内容 hash 修复未完成步骤。若 Markdown 继续是真相，至少增加可恢复写前日志与补偿，避免宣称跨资源原子性。

验收条件：1. 对写临时文件、替换、COMMIT、事件发送前后逐点注入失败和进程中断，重启后文件、版本、hash 和审计记录一致。 2. 失败结果不得悄悄留下未记账的成功；恢复不得把系统失败写入归给用户。 3. 验证 Windows 文件占用与 SQLite WAL 备份恢复。

DATA-02 恢复讲义生成时重新取基准版本 会覆盖停机期间的外部编辑

优先级 P1 · 已通过合成恢复流程复现

问题与根因：正在运行的一次生成有乐观锁，但跨重启后丢失最初的编辑基准。恢复把最新外部修改误当作允许覆盖的起点。

影响与边界：用户在应用中断后用 Obsidian 或其他编辑器补写的笔记，会被恢复的后台生成覆盖。变更日志可能保留该文本，因此不能等同不可恢复删除，但用户没有收到预期的冲突阻止。

验证/触发条件：R05：先生成讲义；让下一次生成中断并模拟 running 持久态；关闭 harness、外部写入独特笔记、重启；恢复状态 ready 且独特笔记从当前文件消失。使用与仓库恢复测试类似的状态注入，未声称真实 SIGKILL 测试。

源码与证据：

packages/textbook/src/index.ts:157-185,813-828,1072-1084,1115-1122 Run 不保存初始文件 hash；每次 writeStage 重读 before，最后以本次 before.hash 作为 CAS，resume 重用同一 run 的 parts。

建议方案：在生成开始时持久化 baseHash/baseVersion 和 baseText 引用，所有重试与恢复沿用同一基准。发现不一致时保留生成草稿，交给用户查看差异、选择合并或替换；如用户显式重新生成，应建立新 run 并重新确认基准。

验收条件：1. 恢复过程中遇到外部改动时进入 conflict，原文件逐字保留，生成结果仍可获取。 2. 停机期间未改动则复用已完成回复，不新增重复模型调用。 3. 覆盖不存在文件、已有讲义、删除文件、并发外部编辑四类情况。

补充限定：范围限定为尚未完成发布的 run 恢复：已发布且文件 run 标识与恢复记录相同时，index.ts822–824 会补索引/状态并保留当前文件，因此不是所有启动恢复都会覆盖。

DATA-03 段落编辑接口没有携带打开编辑器时的版本

优先级 P1 · 已通过两个客户端视图顺序保存复现

问题与根因：CAS 保护的是服务端一次处理期间的修改，缺少从读取编辑表单到提交之间的端到端版本条件。

影响与边界：两个标签页/窗口，或页面编辑与 Obsidian 编辑先后保存同一段，后保存者会静默覆盖前者；单用户也可以触发。

验证/触发条件：R04：两个客户端先读取同一段，甲保存重要笔记，乙基于原内容保存；两次都成功，甲内容从现版消失。

源码与证据：

packages/textbook/src/index.ts:479-483,492-520 blockSource 只返回 text；editBlock 先读当前文件，再用当前 hash 进行内部 CAS，无法发现客户端已经基于旧内容编辑。

建议方案：blockSource 返回 blockHash 和 fileVersion，提交必须携带 expectedBlockHash；后端不匹配则返回包含 base/current/submitted 的冲突信息，保留用户输入。优先做段落级合并，避免其他段落变化造成不必要整份冲突。

验收条件：1. 同段第二份陈旧提交被拒绝且用户草稿仍在；不同段可安全合并。 2. 刷新、外部编辑、重生成后的旧编辑器均不能悄悄覆盖新版本。

补充限定：复现通过两个客户端读取视图和真实服务提交模拟，未做两个真实浏览器窗口操作；当前变更历史通常仍可用于人工恢复。

AI-01 讲义公式比对删掉上下标符号 会漏掉改变数学含义的错误

优先级 P1 · 已通过纯函数反例复现

问题与根因：把数学结构当作排版差异删除，产生非等价表达式碰撞；纯字符串包含关系不能证明公式结构未变。

影响与边界：如压强下标 p_2 被写成平方 p^2，检测仍可通过。此项不同于不做逐句语义复核的既定取舍，它直接削弱已有的“公式必须与原文一致”程序保证。

验证/触发条件：R02：原式$p_2=p_1+\rho gh$与生成式$p^2=p^1+\rho gh$均变成 p2=p1+ρgh，precheck 返回 undefined。

源码与证据：

packages/textbook/src/check.ts:85-93,95-119 bareTex 移除^、_和花括号；precheck 按规范化字符串子串判断公式是否来自资料。

建议方案：只消除可证明不影响意义的排版差异，保留上下标、分组、分数与运算符；优先从来源公式对象直接引用。必须比较时使用保持结构的 LaTeX 解析树/受限规范化，解析失败转待核实，不将字符串碰撞视为通过。

验收条件：1. 上下标互换、分母分组、负号、绝对值、分段条件改变均不能通过。 2. 空格、\left/\right 和等价排版可通过，数学语义保持。

AI-02 事实段落缺引用时，没有主动标识来源缺口

优先级 P2 · 运行现象已复现；来源完整性建议

问题与根因：最低来源完整性没有成为独立状态。现有 unverified 专指公式/数值与资料不符，不能把它的 false 解释为事实正确；缺引用另有被动查看提示。

影响与边界：合成的无出处事实陈述可正常发布，citations=[]、unverified=false；用户需要主动打开出处弹窗才看到“这段没有引用资料”。建议在不恢复逐句模型核对的前提下，让知识性段落的缺来源状态更容易被识别。现有界面没有宣称该事实已被证实，文档也明确接受无公式/数值的语义矛盾可能漏检，因此这是一项来源完整性建议，而非已证实的虚假认证。

验证/触发条件：R03：假模型的小节只返回“静止液体的压强随着高度增加而增大。”；生成 ready，该块 citations=[]、original=false、unverified=false。事实方向反转用于证明不应把未检出理解为证实。

源码与证据：

- packages/textbook/src/format.ts:151-169,238-245 移除未知引用后不记录该块缺来源；unverified 仅认字面旧标记。
- packages/textbook/src/check.ts:38-48,111-120 Paragraph 带 citations 但检查只核对习题相似度、式子和数值，不使用引用集合判断最低来源完整性。
- packages/textbook/src/index.ts:1250-1263 索引 unverified 仅来自既有标记或 check 结果。
- packages/textbook/src/client.tsx:93,345 出处弹窗已有“这段没有引用资料”；页头待核实标签的解释限于式子和数值。

建议方案：将 sourceStatus 与 formulaCheckStatus 分开，表示 direct-source、cited、missing、user-edited；对知识性段落缺引用/引用全部被过滤建立可发现的来源汇总和筛选。纯过渡句可豁免。保留已有出处弹窗，遵守不逐句调用 LLM 及不在正文密集插警告的取舍。

验收条件：1. 无来源、全部无效来源、跨课程无关来源的事实段落可区分地显示未核实。 2. 有有效引用的段落保留正常体验；不增加逐句 LLM 调用。

补充限定：docs/textbook/design.md 明确用户选择不逐句模型核对，正文不插大量待核实标记。本建议可采用页头汇总/来源筛选和现有出处入口，不应破坏这个已确认的阅读取舍。

DATA-04 讲义重新索引只新增知识关联 不移除已经失效的关联

优先级 P2 · 已通过服务与 SQLite 复现

问题与根因：块索引和知识引用关系的更新协议只覆盖添加，未做按文件/块所有权的差集替换。

影响与边界：块修改或删除后，讲义端 nodeIds 已变化，知识图谱详情仍显示旧解释链接，出现两份不一致的关联事实，影响出处导航与知识定位。

验证/触发条件：R06：生成关联“压强”的非原文块，编辑成不含相关内容的个人安排；块 nodeIds=[]，learnKnowledge.links(压强)中仍有该块链接。

源码与证据：

packages/textbook/src/index.ts:1250-1276 删除并重建 textbook_blocks 后只调用 learnKnowledge.link 添加当前关联；未清除旧块已不再解释的知识点关联。

packages/knowledge/src/store.ts:582-583 详情只检查 block 存在，不核对其当前 nodeIds；改主题后旧链接仍被视为可用，删除后的链接则已被标为不可用。

建议方案：由 knowledge 提供 replaceOwnedLinks(ownerKey, links)服务，在一个事务中更新该文件/块拥有的关联并删除差集，保留人工或其他来源的链接；不要由 textbook 直接跨表删除。

验收条件：1. 改主题、删块、拆段、重生成、外部编辑后，两个模块查询的关联一致。 2. 批注历史和人工知识链接不受删除差集影响。

补充限定：必须区分改主题的仍存块与已删除块：前者错误显示可用，后者已有不可用标识。

DATA-05 BEGIN 失败会使连接一直处于错误的嵌套事务状态

优先级 P2 · 已通过一次 BEGIN 故障注入复现

问题与根因：事务管理状态在数据库确实开始事务之前就标记成功，异常清理未包住 BEGIN；之后写入实际上按自动提交运行，而 afterCommit 一直等待不存在的外层事务。

影响与边界：一次 BEGIN 失败后，后续业务事务抛错也无法回滚已写入的数据，提交后通知被无限积压，直到连接重建。触发条件是开启事务失败，未声称普通请求必现或做过磁盘损坏实测。

验证/触发条件：audit/learning/begin-failure-repro.mjs：注入一次 BEGIN 失败；下一笔 transaction 插入后抛错，行仍存在；再下一笔正常插入也存在，但两个 afterCommit 均未发出。输出 begin-failure-output.txt。

源码与证据：

packages/core/src/db.ts:49-75 先将 depth 设为 1，再在 try 之外执行 BEGIN IMMEDIATE；BEGIN 抛错时不复位，随后 transaction 直接走嵌套分支。

建议方案：把 BEGIN、回调、COMMIT 放入同一受控状态机；仅在 BEGIN 成功后进入 depth=1，finally 保证 depth/pending 恢复。ROLLBACK 也可能失败，保留原始异常、标记连接不可用并重建；不要继续复用不明事务状态。

验收条件：1. 注入 BEGIN、回调、COMMIT、ROLLBACK 各阶段错误后，下一笔事务有正确的提交/回滚语义。 2. afterCommit 只在对应成功提交后发出，失败队列被丢弃且不吞掉其他错误。

六、学习评估、知识模型与课程生命周期

本组 17 项均有隔离数据运行反例，共 20 条断言通过。需要强调：项目保留了人工决策点，没有发现后台绕过用户自动结课。问题在于用户或老师作出决定时，服务可能提供重复、过期或错误的事实。修复不是再增加一个确认按钮，而是让按钮所依据的事实有一致的版本和有效性。

L01 交卷缺少持久化的提交锁与幂等键，同卷并发或中断重试会重复写入作答证据

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：状态枚举虽然有 submitted，但提交路径没有先原子地占有测试；幂等只对已结束的测试生效，正在判分和部分完成都仍然 open。

影响与边界：单用户的双标签页、手动交卷与计时交卷重叠、网络重试或进程中断都可把一次作答计为多次独立证据；不同重试内容还可能形成虚假冲突。判分期间后续题的草稿与题目也未整体冻结。

验证/触发条件：Promise.all 同交一张一题试卷得到 2 attempts、2 条证据，掌握解释为“独立答对 2 次”；第一题保存后注入中断再重试，一张两题试卷得到 3 attempts。 证据：audit/learning/domain-repro.test.ts（L01、L01b）。

源码与证据：

packages/assess/src/index.ts:397-416 仅在入口检查 open，逐题 await grade，直到全部完成才 finalize；没有冻结提交或跳过已保存题。

packages/assess/src/index.ts:357-394 record 每次创建全新 attempt id，并追加 attempt.graded。

packages/assess/src/store.ts:56-62 attempts 只有 id 主键，无 test_id/problem_id 唯一约束。

packages/assess/src/index.ts:425-435 逐题诊断的 answer 也存在检查后 await 再写入的同类窗口。

建议方案：1. 短事务 CAS 将 open 改为 submitted，保存完整答案、问题版本、submittedAt 和 submissionId；随后异步判分。 2. 对 (submissionId, problemVersionId) 建唯一约束；重试复用同一提交并只处理未完成的题。 3. 为已提交但未判完状态提供恢复路径；不要跨模型调用持有数据库事务。

验收条件：1. 并发提交只产生一组 attempts 和一组原始 graded 事件。 2. 在任意题后中断并重启恢复，attempt 数与试题数一致。 3. 交卷后改草稿/参考答案不影响该提交快照；已冻结时间不随重试变化。

补充限定：不要误称模拟考总分一定翻倍：view 的 verdictOf/find 取首个 attempt；已证实的是证据重复和视图/计数不一致。 修复使用 submitted 状态时，还必须同时改 view 的 !open 返回答案逻辑，否则判分中会提前暴露参考答案。

L02 模型可仅靠 authority/tier 标签把无出处原创题放入测试预留池

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：可靠性依据存为可随意声明的标签，没有用可校验来源构造可信状态；同一问题可以同时为 origin=agent、tier=2、answerSource=authority。

影响与边界：本应隔离原创题与权威验收题的关键保证可被正常模型工具调用绕过；幻觉题干、模型心算答案可成为阶段/结课证据。

验证/触发条件：通过真实 add_problems 工具提交无 chunkId/原题的 tier2 + authority + test-reserved，成功存为 origin.kind=agent 的预留题。 证据：audit/learning/domain-repro.test.ts（L02）。

源码与证据：

packages/assess/src/tools.ts:169-176 tier 2 的 chunkId 只是可选参数，authority 由工具调用者自报。

packages/assess/src/tools.ts:223-240 只有填写 chunkId 才检查；没有出处时 origin=agent，却仍使用所报 tier 与 answerSource。

packages/assess/src/store.ts:169-184 拒绝 tier4/unverified，但未验证 tier2 与出处、权威答案证据的一致性。

建议方案：1. 以来源联合类型表达题目出处和答案依据；tier2 必须引用可追溯来源及明确答案位置，无法证明时降为 unverified/practice。 2. 从引用或计算结果推导 answerSource，不接受无证据的字符串提权。 3. import_exercises 的人工覆盖答案同样应区分解析修正、教师推导和已核验原文。

验收条件：1. 缺来源、无答案引用、来源不在授权资料中的 authority 题被拒绝进入预留池。 2. 有有效原文引用或可重放计算的题可正常入池，并能在界面追溯证据。

补充限定：这不是多租户安全问题，而是单用户本地学习产品的来源可信性不变量。

L03 题目被纠错后，旧作答已在掌握层作废，却仍能让阶段复盘判为通过

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：阶段报告、复盘与掌握层分别解释同一事实，只有 learner 使用作废与帮助规则；固定成 active 的纠错问题在复盘里失去“历史证据已无效”的信息。

影响与边界：已经确认题目/参考答案有错的旧成绩仍显示通过并默认建议下一阶段；风险不被携带。帮助已揭答案时也出现 assisted 与 pass 并列，容易被当作独立验收通过。

验证/触发条件：先正确答题再 fixed 参考答案：learner=untested，解释“有 1 次作答的题目后来核对出有错，不计”；stage=pass、review=pass、recommendation=next。提前或迟到记录 answer-

revealed 时 learner=assisted，阶段仍 pass。 证据：audit/learning/domain-repro.test.ts（L03、L03b、L03c）。

源码与证据：

packages/assess/src/stage.ts:61-75 阶段结果只读取原始 verdict 与开始时 fresh 标记。

packages/assess/src/store.ts:577-587 view 取缓存 grading 生成报告，不读取证据有效性。

packages/curriculum/src/review.ts:66-84 只把 retired 问题排除；fixed 后恢复 active 的问题不被排除。

packages/learner/src/rules.ts:79-101 掌握层正确地将后续 fixed/retired 事件之前的作答置为 void。

建议方案：1. 抽出唯一的有效证据投影，返回每条 attempt 的原始评分、有效评分、void/pending、帮助和新颖性；所有报告共用。 2. 保留“答对”这一原始事实，同时将失效证据显示为不可用于验收，并阻止用其得出通过/无风险。 3. 帮助规则对阶段建议的作用要写进产品政策；至少明确“有帮助完成，独立验收仍待验证”。

验收条件：1. fixed 与 retired 的历史作答均不能支撑阶段/结课验收通过。 2. 迟到日志与重算后各页面对证据有效性的解释一致。 3. 保留原始判分及作废原因，能解释为什么历史得分与当前结论不同。

补充限定：docs/curriculum/design.md 39–40 当前确实把“新题全对”定义为 pass，并另列帮助/掌握状态。因此 assisted/pass 部分是跨层产品政策缺陷；fixed/void 仍 pass 是明确实现缺陷。成功补记迟到 help 后 learner 会立即纠正，不应声称它永久错判。

L04 显式指定阶段/结课题目会绕开必需蓝图，生成无法完成正常复盘的测试

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：Test.kind 与 plan/scope/mock/final 是彼此独立的可选字段，工具允许选择题目却跳过不可省略的验收结构。

影响与边界：模型合法使用 problemIds 发布阶段测试后，用户作答完毕却无法保存复盘；显式 final 也缺用于识别当前结课检验的 stageIds。该路径还跳过自动组卷的新题检查。

验证/触发条件：真实 start_test 工具以 kind=stage、problemIds 发布；交卷后阶段 reviewing，但 stageReport 不存在，save_stage_review 报“找不到这个阶段判过分的阶段测试”。 证据：audit/learning/domain-repro.test.ts（L04）。

源码与证据：

packages/assess/src/tools.ts:342-365 final 和 stage 的必需计划仅在 !problems 时构造。

packages/assess/src/store.ts:302-378 显式 problemIds 分支只查题池/状态，不要求 stage.plan 或 final.final。

packages/curriculum/src/index.ts:315-320 这种 stage 测试仍会把阶段推进到 reviewing。

packages/curriculum/src/tools.ts:28-31 复盘仅接收具有 stageReport 的已判分测试。

packages/curriculum/src/tools.ts:185-190 缺 stageReport 时正常 save_stage_review 直接失败。

建议方案：1. 用 discriminated union 约束不同测试种类的必要计划。 2. 显式指定题目时也生成/验证完整蓝图和目标映射；或限制该参数只用于允许无计划的测试种类。 3. 在 store/service 层统一校验，避免只有工具做保证。

验收条件：1. 对每个 Test.kind 运行自动选题与显式选题的完整生命周期。 2. stage 始终可复盘，final 始终可生成当前目标对应报告；不合格输入发布前失败。

L05 表达式“等价”只在 0.5–2 的随机正数上抽样，非恒等式被确定判对

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：有限正区间上的数值一致被当成全定义域数学等价；问题模型没有变量定义域，绝对误差下限也会把小量零化。

影响与边界：符号、绝对值、分段函数、奇点和小量公式可被误判正确，并写入确定的独立掌握证据；变量范围不明时尤其危险。

验证/触发条件：sqrt(x^2) 对参考 x 稳定得到 correct，但 x=-1 时为 1 != -1。另用纯函数实际检查 abs(x)/x、x<2?x:999/x、0/1e-7 均返回 equivalent=true。 证据：audit/learning/domain-repro.test.ts（L05）。

源码与证据：

packages/assess/src/grading.ts:77-98 每个变量仅在 [0.5,2) 抽样，几次相近就返回 true。

packages/assess/src/grading.ts:103-107 抽样 true 被直接转为 correct/score1。

建议方案：1. 限定表达式语法并在明确变量域中使用可证明的符号等价/规范化规则。 2. 数值抽样只用于发现反例；无法证明时返回不确定或进入可复核判分，不能以几次命中给数学证明级确定性。 3. 覆盖负值、零、极值、奇点和量级；保存域/规则版本以供审计。

验收条件：1. sqrt(x^2) 与 x 在未知实数域不自动判同，在明确非负域可合法识别。 2. 分段伪等价、奇点/量纲/极小常数的边界用例不被肯定误判。

补充限定：表达式执行副作用与资源边界见 SEC-04；本项专门讨论数学等价性的判定，二者应分别验收。

L06 并行小节抽取以过期图快照去重，正常抽取会制造同名歧义节点

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：防重校验发生在长模型调用之前，提交阶段既不刷新 known，也不对系统生成节点执行原子的复用判定。

影响与边界：相邻章节共用概念时会生成重复身份，按标题关联教材/出题报歧义；证据、先修关系和来源散落在不同节点，需要手工合并。

验证/触发条件：同一课程同时抽取 1.1、1.2，两次合成模型均输出“共同概念”；最终同名节点 2 个，resolve 报同名/别名对应多个节点。 证据：audit/learning/domain-repro.test.ts（L06）。

源码与证据：

packages/knowledge/src/extract.ts:25 抽取并行度固定为 2。

packages/knowledge/src/extract.ts:302-321 模型调用前捕获 known，调用后仍用旧快照检查，然后以 system 添加。

packages/knowledge/src/store.ts:341-356 同名保护只作用于 actor=teacher，system 抽取绕过。

packages/knowledge/src/store.ts:718-724 同课同名被认为是用户刻意选择，不自动建议合并。

建议方案：1. 模型完成后在提交事务内重新读取当前图，并按规范化标题/别名/类型处理可复用身份。 2. 把“用户明确创建不同身份”与“系统自动创建”区分，后者不得绕过同名检查。 3. 请求级幂等之外增加身份级一致性；无需序列化整个模型等待。

验收条件：1. 两个并行小节产生相同概念时落为一个节点、两份来源。 2. 含义不同但同名的内容进入待区分队列，不静默重复或误合并。

L07 学习中的阶段可以直接重写设计并清除确认，但再也无法确认新设计

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：设计修订沿用了首次起草流程，缺少已开始阶段的修订状态机；保存文件、修改课时和清确认同时直接生效。

影响与边界：已确认并进行中的课程内容在未重新同意时改变；页面/服务一边显示草稿未确认、一边保持学习中且拒绝确认。未开始课时 ID 重建还会破坏已有引用并留下混杂结构。

验证/触发条件：构造已确认 learning 阶段后 saveDesign；stage.status 仍 learning，designConfirmedAt 消失，confirmDesign 报“没有待确认的设计”。 证据：audit/learning/domain-repro.test.ts（L07）。

源码与证据：

packages/curriculum/src/index.ts:158-175 saveDesign 无阶段状态限制，清 designConfirmedAt 但保留 learning/testing/reviewing/done；confirmDesign 只接受 designing。

packages/curriculum/src/store.ts:173-194 修订会删除所有未开始课时，重建新 ID；已开始却未列入新稿的课时仍保留。

建议方案：1. 初期可先明确拒绝正在学习及之后状态的原地 saveDesign，并提供受控修订入口。 2. 成熟实现将新设计作为有基线版本的草稿提案，确认后迁移课时/任务；已开始的记录保留历史版本。 3. 按稳定课时身份更新，明确删除、重排和保留规则，避免全删重建未开始课时。

验收条件：1. 每种阶段状态对设计修订的行为明确且可恢复。 2. 新设计真正确认前当前设计与进行中任务保持一致；确认后不产生孤立 lessonId 或重复序号。

L08 撤回测试会暴露参考答案，却不将预留题记为已见，之后仍当新题组卷

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：答案可见性被简化为 open/非 open；曝光记录没有覆盖撤卷状态。

影响与边界：一次未作答但看过或已被回包暴露答案的试卷撤回后，可再次作为“没见过”的正式验收题；削弱新题迁移与延迟验证的可信度。

验证/触发条件：撤回一张预留题阶段测试，返回 problems[0].answer；下一张自动蓝图测试再次选同题且 plan.fresh 包含它。 证据：audit/learning/domain-repro.test.ts（L08）。

源码与证据：

packages/assess/src/index.ts:696-705 withdraw 直接 abandoned 并返回 view，没有 problem.seen。

packages/assess/src/store.ts:562-570 只要不为 open 就返回完整 answer，abandoned 也包括在内。

packages/assess/src/store.ts:288-299 fresh 集合只从已作答/seen/作业得到。

packages/assess/src/index.ts:708-718 dropCheck 特意记 seen，而普通撤卷没有同样保护。

建议方案：1. 单独定义各状态的题干/答案可见性，未交卷撤回不应默认公开答案。 2. 在题目实际显示或答案公开时记 exposure/seen；自动组卷用跨课程的题目身份/版本曝光记录。 3. 区分“尚未展示的撤销”和“已经展示后的撤回”。

验收条件：1. 撤回已看过试卷后，同题不再进入新题列表。 2. 尚未打开的限时试卷撤销不泄露答案；不会因无意义发布消耗新题。

补充限定：已证实服务返回和历史 view 可得到答案；没有在真实浏览器验证 abandoned 页是否逐题渲染答案，不应声称 UI 已必然展示。

L09 题目原地可变但作答未保存题目版本，历史试卷会换成新参考答案

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：证据事件不可变，但其所引用的题目语义不是不可变对象；重放只有评分事实，没有当时判分上下文。

影响与边界：用户回看历史记录会看到“答 2、判正确、参考 99”；难以解释初判/改判和题目纠错，开放题 rubric 修改后也失去可复核依据。判分过程中改题还可能影响尚未处理的后续题。

验证/触发条件：提交答案 2 得 correct；reviewProblem fixed 将答案改 99；原历史 test view 立刻显示参考 99，原答 2 与 correct 保持。 证据：audit/learning/domain-repro.test.ts（L09）。

源码与证据：

packages/contracts/src/schema/assess.ts:159-175 试卷仅保存问题 ID，无题目版本或题面快照。

packages/contracts/src/schema/assess.ts:210-225 Attempt 保存答卷但没有其面对的题面、答案/rubric 版本。

packages/assess/src/store.ts:210-214 saveProblem 原地覆盖。

packages/assess/src/store.ts:565-577 历史 view 读取当前问题，配原有 attempt grading。

建议方案：1. 引入不可变 ProblemVersion，Test/Attempt 固定其 ID；题面、答案、评分 rubric、来源、计算和判分规则版本一并追溯。 2. 纠错产生新版本并独立标记旧证据是否无效；历史视图同时说明原版本和后续纠正。

验收条件：1. 修改题目后历史试卷仍显示原先实际作答题面/参考答案，并明确后续纠错。 2. 同一题版本在重试、重判与证据重放中保持一致。

L10 目标版本检查不是原子比较并交换，同版本并发修订均成功且丢失内容

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：乐观锁只校验读时的文档版本，真正写时没有 CAS；单用户页面事实编辑与老师修订可以并发。

影响与边界：两次操作都返回成功和同一新版本，后写覆盖先写，用户或老师的修改悄悄消失；目标条目、资料绑定和条件的可信历史被削弱。

验证/触发条件：对 v1 并发 revise purpose 和 revise level；两次均返回 v2，最终仅保留 level 改动，purpose 回到原值。 证据：audit/learning/domain-repro.test.ts（L10）。

源码与证据：

packages/goal/src/index.ts:209-237 读取版本后异步进入 commit，两次调用可读取相同 before。

packages/goal/src/index.ts:193-194 写入只使用 before.version+1，不传文件基线 hash。

packages/goal/src/index.ts:240-276 setFacts 同样先查版本后无条件写入；setSource/acknowledge 同类。

packages/core/src/store.ts:186-191 底层已有 ifHash 冲突保护，但 goal 没使用。

建议方案：1. 从 goal.get 返回实际文件 hash，并将其作为 write 的 ifHash；或用课程文档级串行变更服务。 2. 冲突返回当前版本和可复核差异，重读后合并非重叠字段；不能静默覆盖。 3. 不要把所有 get 错误吞成“目标不存在”，解析失败应保留文件并明确报告。

验收条件：1. 同一基线的并发写至少一项明确冲突，或合并后得到连续版本且两项内容均保留。 2. 用户 setFacts 与教师 revise 的竞态也覆盖。

补充限定：修复可与 DATA-03 的端到端版本条件共同设计；目标修订仍应单独验证已有 ifHash 条件是否被正确使用。

L11 数值判分只取数字前缀，维度未知时无条件忽略尾部内容

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：解析失败、无量纲、未知复合单位三种语义混在 undefined 中，并采取宽松的“只比较数字”回退。

影响与边界：格式错误、未算完的表达式和明显错误量纲被判确定正确；对无量纲量及质量分数/百分比常见的化工学习尤其不可靠。

验证/触发条件：参考无单位 2 时答案“2+100”“2 kg”均 correct；参考 20% 时“20 kg”也 correct。 证据：audit/learning/domain-repro.test.ts（L11）。

源码与证据：

packages/assess/src/units.ts:81-95 splitQuantity 只解析开头数字，将剩余所有内容当作 unit。

packages/assess/src/units.ts:64-73 unitOf 不能识别 % 等无字母维度表达。

packages/assess/src/grading.ts:16-39 参考单位未识别或无单位时仅比较数字，不验证尾部、单位或表达式。

建议方案：1. 完整消费答案字符串：数字后只允许可识别单位/明确计数词，剩余运算符必须求值或返回待核对。 2. 将 dimensionless、recognized-unit、unknown-unit 分开表示；未知单位不能默认为确定可忽略。 3. 显式支持 %/ppm/比例量与规范化量纲；未知教材复合单位至少要求一致文本或人工复核。

验收条件：1. 2+100 不被当作 2；无量纲参考拒绝 kg 等有量纲答案。 2. 20%、0.2 等等价比例按既定规则一致，20 kg 不通过。 3. 保留现有常见化工单位、科学计数法和中文单位的正确转换。

L12 诊断把所有“部分对”当作已会，多问题一问全错也会跳过先修探测

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：partial 是过粗的聚合枚举，调用者将它误当作“方法正确只差单位”，未检查分问/原因。

影响与边界：摸底会高估基础、跳过应探的先修；同一份作答显示诊断已会但掌握层还没答对，影响后续课程起点。

验证/触发条件：两问数值题答 2 和 999，分问为 correct/incorrect，整题 partial，诊断 known，learner not-yet。 证据：audit/learning/domain-repro.test.ts（L12）。

源码与证据：

packages/assess/src/store.ts:381-388 除了 incorrect/pending-review，所有 verdict 都映射为 right，包括任何 partial。

packages/assess/src/grading.ts:121-141 多问题有对有错会得到 partial，不仅是漏单位。

packages/assess/src/adaptive.ts:7-11 right 的约定只应为 correct 或仅缺单位。

packages/assess/src/adaptive.ts:88-118 right 直接给 known，并推断/跳过其先修。

建议方案：1. 给判分增加结构化错误原因，如 missing-unit/partial-steps/wrong-part，诊断只对白名单情况放宽。 2. 无法区分原因时把 partial 作为不确定或需要继续探测；多节点/分问题按可定位证据处理。

验收条件：1. 任一关键分问答错不直接判该节点 known；缺单位政策单独覆盖。 2. 诊断推断不进入独立掌握证据，并向用户解释二者差异。

L13 模型判分耗时被算作学习者超时和作答时长

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：交卷完成与判分完成共用一个结束时刻；虽然 attempt 保留提交时间，计时报告没有使用它。

影响与边界：按时交卷会被标为超时；慢模型、多题试卷和重试会放大作答时长，错误反馈学习者的速度表现。

验证/触发条件：合成时钟：05:00 开始，05:01 截止，05:00:59 提交，判分到 05:02:30；结果 overtime=1 分钟。没有实际等待或真实模型调用。 证据：audit/learning/domain-repro.test.ts（L13）。

源码与证据：

packages/assess/src/index.ts:408-416 已记录 lockedAt，但 overtime 仍在全部异步判分完成后用 Date.now 计算。

packages/assess/src/index.ts:466-468 endedAt 是判分结束时间。

packages/assess/src/store.ts:588 模拟考分钟数由 openedAt 到 endedAt 计算。

建议方案：1. Test 保存 submittedAt 与 gradingCompletedAt；时长/超时仅比较服务器接受并冻结提交的 submittedAt。 2. 计时截止与上传、识别确认的政策单独定义，不把后端模型时间转嫁给学习者。

验收条件：1. 相同答卷提交时刻下，判分延迟从 0 增到数分钟，作答时长和超时结果不变。

L14 知识身份合并后阶段仍引用旧身份，正常自动组卷找不到当前节点的新题

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：知识层正确保留旧身份用于历史，但课程/组卷/报告消费者没有统一解析 canonical identity；合并没有覆盖这些持久化引用的语义。

影响与边界：正常合并完成后，有题却报缺题；前测/阶段/结课核心节点及先修映射可能分裂，报告还可能查询旧身份状态而漏掉合并后的证据。

验证/触发条件：阶段设计引用节点 A，将 A 合入 B，给 B 添加新预留题；普通 start_test(kind=stage) 报“没有本阶段核心知识点的新题”，stage.nodeIds 仍是 A，而 identity(A).current=B。 证据：audit/learning/domain-repro.test.ts（L14）。

源码与证据：

packages/knowledge/src/store.ts:649-659 identity 返回 current 和该节点的历史 children，旧节点不会在 merged 中自动包含其 current。

packages/assess/src/tools.ts:77-85 probeNodes 使用输入 ID 原样构造核心节点，没有归一到 identity.current。

packages/assess/src/tools.ts:353-365 自动阶段蓝图直接读取 stage.nodeIds。

packages/curriculum/src/report.ts:23-26 课程报告也直接读取阶段保存的 nodeIds 的状态。

建议方案：1. 建立统一 resolveIdentity 输入投影，对阶段/风险/目标映射等当前决策解析 current 并去重。 2. 历史日志和历史题面保留原 ID；当前组卷节点使用 current，并把所有历史别名 ID 放入 also。 3. 合并/撤销后失效相关缓存和待发布蓝图，明确处理已保存复盘。

验收条件：1. 合并前后同一阶段都能使用当前身份的新题。 2. 多次链式合并及撤销后，前测/最终报告/掌握查询的一致性不丢失。

L15 保存复盘后改判不会使待决定的复盘失效，失败可以沿旧通过结果无风险推进

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：复盘是有依赖的决策快照，但没有依赖版本/fingerprint 或 stale 状态；作答纠正和用户最终决定之间无一致性校验。

影响与边界：老师先保存通过复盘，随后复核为错误，用户仍可根据旧表进入下一阶段且不携带风险。新申诉、问题核查等同样可能绕过保存时才做的 blocker 检查。

验证/触发条件：真实工具保存 pass 复盘后 regrade incorrect：即时 stageReport=fail，saved review=pass；decideReview(next) 成功，carried 风险数为 0。 证据：audit/learning/domain-repro.test.ts（L15）。

源码与证据：

packages/curriculum/src/index.ts:234-255 saveReview 将当时结果复制为固定 review.nodes。

packages/curriculum/src/index.ts:258-286 decideReview 只读已保存结果，不重新验证 test/证据版本或未处理申诉。

packages/assess/src/index.ts:572-601 regrade 更改当前评分、追加事件，但没有使已保存复盘过期。

packages/curriculum/src/review.ts:29-40 风险携带只取已决定的旧 review.nodes。

建议方案：1. 保存复盘时记录依赖的测试提交、评分与有效证据版本；发生改判/撤证/新申诉时标为待更新。 2. 最终决定前重新计算并检查事实指纹/阻塞项，变化则要求刷新并复核差异。 3. 已决定的历史记录可以保留，但后续更正必须明确携带风险/补充结论，不能静默沿用。

验收条件：1. 保存与决定之间改判或新增申诉，不能无提示按旧 pass 前进。 2. 风险携带与用户当次确认的最新事实一致。

L16 结课测试换题不更新目标条目的问题引用，替补题答对仍被算作没答

优先级 P2 · 真实服务/函数运行反例；合成数据

问题与根因：换题逻辑为多个测试计划分别手工同步，新加入的 final 计划没有纳入统一映射。

影响与边界：用户依法报告“这题做过/题有问题”并完成替补题后，结课目标被误报未答/未检验，报告漏记实际作答，可能要求无意义补测。

验证/触发条件：一目标两道候选预留题，首题 done-before 后换成第二题并答对；attempt correct，但 finalReport 目标 outcome=insufficient、problems=[]，计划仍指向旧题。 证据：audit/learning/domain-repro.test.ts（L16）。

源码与证据：

packages/assess/src/index.ts:518-525 report 换题时更新 Test.problemIds、stage.plan 和 mock.sections，但遗漏 final.items.problemIds。

packages/assess/src/final.ts:53-68 finalReport 只按 plan.items 保存的问题 ID 查 verdict 和题号。

建议方案：1. 将题目替换抽成对所有 kind 计划都维护的原子操作，重算目标覆盖/未覆盖列表。 2. 替补不再覆盖原目标或跳题无替补时明确更新缺口，不能保留悬挂引用。

验收条件：1. final 单次/多次换题、无替补跳题的目标题号和结果全部对应真实当前试卷。 2. stage/mock 的既有换题行为保持一致。

L17 结课检验没有绑定目标语义版本，旧测试可为大幅修订后的目标背书

优先级 P1 · 真实服务/函数运行反例；合成数据

问题与根因：稳定条目键被同时当作语义未变化的证明；目标修订虽然重新要求确认，却没有失效旧验收和更新所需证据范围。

影响与边界：完成较小目标的旧试卷可以让完全升级后的能力目标显示“做到了”；这是实际学习达成声明的错误，不能靠用户确认新文字弥补。

验证/触发条件：旧目标“按给定参数计算静水压强”完成唯一 final；同 key 修订并确认“独立设计完整传热网络并优化运行参数”；不增加测试即可 save_course_report，报告新目标 status=done。 证据：audit/learning/domain-repro.test.ts（L17）。

源码与证据：

packages/contracts/src/schema/assess.ts:143-155 FinalPlan 保存文本和 stageIds，但没有目标版本/目标语义 fingerprint。

packages/contracts/src/schema/assess.ts:188-190 currentFinal 仅按 stageIds 判断仍适用。

packages/curriculum/src/tools.ts:57-70 报告取当前 goal.canDo 与旧 final；不核对语义变化。

packages/curriculum/src/report.ts:23-30 仅凭相同 item.key 对齐，旧 final pass + 原节点独立就给当前条目 done。

建议方案：1. 目标条目保留稳定 identity，同时维护 semantic revision；FinalPlan 固定目标版本、支持阶段/节点版本及测试条件。 2. 实质目标或验收标准变更后标记旧 final 只对原版本有效，要求补充验收/明确映射迁移，不能自动等同。 3. 轻微措辞/事实变更与能力范围变化使用明确规则和可审查迁移记录区分。

验收条件：1. 扩大能力范围/改验证标准时旧 final 不再认证新版本。 2. 纯措辞修订可在可验证的等义映射下复用，历史报告仍指向当时目标版本。

相关静态边界，未计入 17 项运行反例

新题识别还有查询范围问题：assess.seenProblemIds 只取当前课程至多前 10,000 条相关日志，而 core 默认升序返回。较晚的曝光或另一课程的同一全局题目可能漏掉。应建立全局题目/版本曝光索引，或无截断 DISTINCT 查询，并明确改编题、重复导入和同源题的“新颖性”政策。learner 本身已按 5,000 条与 after 游标分页，不能把这个 assess 问题误报为 learner 重放截断。

依据：packages/assess/src/store.ts:289-299；packages/core/src/store.ts:303-313；packages/learner/src/index.ts:77-84

教师覆盖解析答案时，应保存核对依据及答案版本，不能仅因原文存在 printed 字段就把任何覆盖结果继续标为书后答案。这与 L02/L09 同属来源和版本治理；合法的 OCR 纠错必须能做，但要分清“修正识别”和“重新推导”。

依据：packages/assess/src/index.ts:162-179

mock 任务被映射成 stage-test，可将阶段置为 testing，而完成回调只有真实 stage 测试才转 reviewing。需要用真实 Test.kind 驱动状态迁移。这里只确认静态路径不对称，未证明所有模拟考都会永久锁死课程，planner 也不完全依赖这个状态。

依据：packages/assess/src/tools.ts:27-27；packages/curriculum/src/index.ts:315-326

learner 缓存启动修复检查规则版本和日志计数，不能覆盖“缓存部分行丢失但 meta 仍完整”的所有情形。建议增加构建代数/完整性检查或缺失时按需重算；当前已有手工重算能力。本轮没有模拟磁盘损坏，不把潜在修复窗口等同已发生数据损坏。

依据：packages/learner/src/index.ts:164-176

现有 3 天延迟、14 天复习、1 天帮助窗口等是清楚可解释的工程启发式，不能当成经本项目真实学习数据校准的概率或教育效果保证。是否适合化工计算题、同构题难度和长期保持，应该通过小规模真实试用验证。固定天数本身不是代码错误。

依据：packages/learner/src/rules.ts:19-26

七、前端交互、可访问性与批注

真实 DSH 空库检查覆盖首页、设置六分区、资料库、知识模型及导航，共 8 组、51 张逐张查看的截图、74 次布局采样；在 1440/1024/760/390 宽度和明暗主题下，未记录控制台错误、警告或横向溢出，逐张截图未见明显布局破坏。这个结果说明基础布局和加载装配可以工作，不能外推到长讲义、多题作答、长聊天、软键盘、真实 iOS/Android 或全课程流程。

前端最需要修的是用户输入和资源身份的生命周期：保存是否真正收到确认，切换课程后旧会话能否继续写，流重连后是否仍在接收，后台标题能否改变当前焦点。视觉上“已连接”“已保存”“当前课程”应与底层事实一致。

FE-01 作答自动保存会吞掉失败、提前清除脏状态，交卷也不等待已发出的保存请求

优先级 P1 · 局部运行复现；非完整业务 UI 验收

问题与根因：把“已发起请求”当成“已持久化”，没有每题保存队列、版本或待确认请求集合；错误被静默消化。

影响与边界：网络/服务器失败后，最后一次答案不再处于 unsaved 集合，页面没有失败提示或自动重试；离开/刷新可丢失作答。转写确认保存已在路上时立即交卷，服务器可能仍读到未确认草稿。后端并发提交与判分幂等问题另见 L01。

验证/触发条件：拒绝 assess.draft 请求：store 返回 fulfilled、dirty 集合变 0，用户看不到失败。；让一次 draft 请求保持 pending，timer 已经触发删除；调用 flush 会立即返回，随后 submit 可先到服务器。

源码与证据：

- packages/assess/src/client.tsx:712-730 store 先删除 unsaved；计时器触发后从 timers 移除；flush 只检查 timers，不跟踪 in-flight Promise。
- packages/assess/src/client.tsx:742-745 handIn 只等待仍在 timers 中的 flush，随后立即 submit。
- packages/assess/src/client.tsx:883-892 界面承诺随时自动保存，但 saveDraft 把全部错误 catch 为空。
- packages/assess/src/client.tsx:706 answerOf 不携带 transcription.confirmed，交卷需要服务器已有确认草稿。

建议方案：1. 每题维护 latest revision、dirty snapshot 及串行保存 Promise；只有对应版本收到 ACK 才清脏。 2. 保存错误在答案旁显示，并保留可重试草稿；保存中/已保存/未保存有明确状态。 3. 交卷、识别、离开之前的 flush 等待所有排队与在途保存；最好让提交携带确认状态并由服务器一次校验并冻结。

验收条件：1. 断网输入、恢复、重试、刷新后最后一版答案完整；失败期间明确显示未保存。 2. 人为乱序两个保存请求，持久化结果仍是最新版本。 3. 延迟确认保存并立即交卷，不出现读旧确认状态或丢答案。

验证方式：async-state-repro.mjs 提取未改动 store/flush/saveDraft 函数，async-state-result.json：surfaced=false, remainingDirtyEntries=0, flushReturnedBeforeSave=true；不是完整浏览器测试。

FE-02 切换课程时侧边会话仍可操作上一门课；新课程加载失败后可无限保留旧会话

优先级 P1 · 局部运行复现；非完整业务 UI 验收

问题与根因：同一资源的后台刷新与资源身份变化共用保留旧数据的策略；课程作用域没有成为组件/查询身份的一部分。安装的 DSH SlotOutlet 也只按注册 entry 稳定 key，并不会因 ownerProps.courseId 变化强制重挂载。

影响与边界：主界面已进入 B 课，右侧仍显示 A 课聊天；用户可将 B 课问题发送到 A 会话，或结束 A 会话并写 A 课总结。B 课 active 请求失败后旧内容长期存在且没有加载错误提示。

验证/触发条件：A 课已有打开的侧边会话；保持右侧栏打开，切换到 B 课。；延迟或拒绝 B 课 sidechat.active；旧 A session 仍被渲染且输入可用。

源码与证据：

packages/sidechat/src/client.tsx:49-80 CourseSideChat 在课程变化时没有 key；active 的 deps 是 courseId。

packages/sidechat/src/client.tsx:108-126 session 直接取 active.data；只在 data===undefined 时显示加载；旧 session 仍可 close/Chat 发送；未展示 active.error。

packages/kit/src/client.ts:33-42 deps 变化 reload 保留 previous.data，失败也保留。

packages/shell/src/client.tsx:1062-1063 右侧槽只改变 scope props，没有按课程重建。

建议方案：1. 按 courseId 给 CourseSideChat 加 key，并将 summary/draft/unsent 跟课程身份绑定。 2. useLoad 区分 identity change 和 same-key refresh；新身份的数据不可继续用于写操作。 3. 显示 active.error 并提供重试；mutation 前校验数据所属 courseId 与当前 scope 相等。

验收条件：1. A/B 两课快速切换、加载延迟及失败下，不在 B 课显示或发送到 A 会话。 2. 本课草稿和上次总结不串课；返回 A 课可恢复其正确会话。

验证方式：async-state-result.json 复现 useLoad 在 B 加载中及失败后保留 chat-a；槽稳定身份已核对安装的官方 DSH renderer。没有声称已执行真实双课程 UI 操作。

FE-03 后台页面异步补全标题会抢走正在操作的标签页

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：标题元数据更新复用了带导航副作用的 setTab，隐藏页面也可以执行。

影响与边界：打开资料后切到作答页，后台书名/讲义标题返回时会自动切回该页，打断输入和阅读位置。

验证/触发条件：先激活作答标签；让另一个后台资料标签完成加载并调用 frame.setTitle。；提取真实 ShellState 配最小 dockview panel 桩：before=answering-tab，retitle 后 after=loading-book-tab。

源码与证据：

- packages/shell/src/client.tsx:385-393 setTab 无条件激活非 active panel。
- packages/shell/src/client.tsx:407-412 retitle 调用 setTab。
- packages/textbook/src/client.tsx:243 讲义异步取到标题后 frame.setTitle。
- packages/library/src/client/reader.tsx:65-66 原文异步取到标题后 frame.setTitle。

建议方案：1. 分离标题/参数更新与用户导航；retitle 路径禁止 setActive。 2. 标题更新不写最近访问顺序，也不切换 active 或 history 指针。

验收条件：1. 后台文档/讲义标题返回、历史页面补全标题均不改变焦点或当前页。

验证方式：retitle-repro.mjs 从固定提交动态提取 ShellState 实现，复用真实 tabs 函数配最小 panel 桩；结果 after=loading-book-tab、events 包含 setActive；不是完整 Dockview/React UI。原审查的提取副本与动态版结果一致。

FE-04 学习变更 SSE 重连只恢复连接灯，断线期间的数据变更不会补同步

优先级 P2 · 静态控制流/生命周期确认

问题与根因：把载体重新连接当成数据已同步，没有 reconnect invalidation 或游标补偿。

影响与边界：后端在断线时完成导入、讲义或测试，重连后页面可能一直显示旧任务/旧状态，而状态栏显示已连接；隐藏 tab 和模块级批注缓存也受影响。

验证/触发条件：打开测试/导入/讲义页，断开学习 SSE；在此期间通过另一个连接完成状态变更。；恢复连接，服务器只发 ready 且不再发生相关事件；页面保持旧状态。

源码与证据：

- packages/shell/src/client.tsx:728-745 ready 只把 feed 改为 open；只有 message 才通知订阅者。
- packages/core/src/index.ts:115-143 事件没有 id/sequence；新连接只发送 ready，无事件回放。
- packages/kit/src/client.ts:44-67 useLoad 只对收到的 feed 事件或可见性 stale 刷新；未收到的事件无法标脏。

建议方案：1. 简单可靠的本地方案：每次 ready（含重连）发布 reset/invalidate，立即刷新可见查询并把隐藏查询标脏。 2. 若需要增量恢复，再引入单调事件 id、有限回放及过期后全量同步。

验收条件：1. 断线期间完成导入/交卷/修改批注后重连，无额外用户操作即可一致。 2. 快速断开恢复不导致成倍订阅、刷新风暴或旧响应覆盖。

FE-05 useLoad 的空 refreshOn 数组实际订阅了所有事件

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：字符串化筛选列表没有区分空集合和空前缀。

影响与边界：只需首次/依赖变化加载的接口被任何 feed 反复调用；后台任务频繁更新时放大读取。编辑期间后台正文发生改变时，误触发的加载会通过 setText 覆盖本地草稿。单纯相同字符串重载不会触发这个覆盖，不能夸大为每个事件必丢字。

验证/触发条件：useLoad(load, deps=[], refreshOn=[])完成首次加载后投递 unrelated/event。；等待 150ms 去抖，load 次数从 1 变 2，预期仍为 1。

源码与证据：

- packages/kit/src/client.ts:44-55 [].join('|')变成''；''.split('|')是['']，任何 type.startsWith('')均 true。
- packages/textbook/src/client.tsx:100-104 BlockEditor 明确传[]，重新加载后的 loaded 会写回编辑文本。
- packages/library/src/client/reader.tsx:71 pageChunks 明确传[]。
- packages/goal/src/client.tsx:222 出处批量读取明确传[]。

建议方案：1. 直接使用数组并对空数组不注册 feed，或 split 后过滤空字符串；区分省略参数的默认行为。 2. 编辑器只有未变脏时才接受后台文本，已编辑时提供冲突提示。

验收条件：1. []不刷新；缺省参数按 learning/刷新；指定前缀只匹配对应事件。 2. 编辑中收到无关 feed 不增加 blockSource 调用也不替换文本。

验证方式：async-state-repro.mjs 的未改动 useLoad+有限 hook 语义桩，结果 beforeFeed=1/afterFeed=2。

FE-06 聊天流中断后不会重新订阅；再次发送成功会清掉错误但无法收到回复

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：自定义 Chat 直接调用一次性 remote.session.follow，没有使用 DSH 的 SessionEventStream/RemoteJournalStream 重连协议。

影响与边界：短时掉线/服务重启后主老师和侧边聊天需要重挂载才能继续实时更新。中断发生在 turn/start 后时 busy 不复位；发送新问题即使成功，也清掉原有错误而界面继续等待。

验证/触发条件：follow 先发 snapshot、turn/start，然后抛载体异常。；恢复载体并 rerender 同 session，再 send 成功；follow 调用数仍 1，busy=true，error 已变 null。

源码与证据：

packages/kit/src/client/chat.tsx:219-244 follow 异步循环退出只设 error/loaded；effect 只依赖 remote/sessionId，没有重连或重试。

packages/kit/src/client/chat.tsx:246-259 发送成功不重建 follow，并预先清 error/setBusy(true)。

packages/kit/src/client/chat.tsx:321 Composer 在连接失败后仍可发送。

.tools/dsh/node_modules/@deepseek-ai/dsh-api-gateway/lib/client.js:346-356 固定 DSH 依赖的物理重连会 failAll 逻辑流。

.tools/dsh/node_modules/@deepseek-ai/dsh-api-gateway/lib/client.js:957-1062 官方 RemoteStream 封装才负责跨载体 generation 重开逻辑流。

建议方案：1. 优先复用官方会话流生命周期与 cursor/assistant baseline 处理；或显式在载体恢复后重订阅并校验序号。 2. 连接状态与模型运行状态拆开；中断显示重连/重试动作，发送成功不掩盖仍断开的订阅。

验收条件：1. 老师回复中断网、恢复后新旧消息都能补齐且不重复。 2. 服务重启后无须关闭页面即可接收下一次回复；终止或异常不遗留永久 busy。

验证方式：chat-repro.mjs 提取 Chat 状态/effect（JSX 换为状态观测），chat-result.json 记录 followCalls=1、成功发送后 busy=true/error=null；官方固定版本传输代码静态核对。

FE-07 聊天只显示 DSH 默认最近 50 条消息，重开后更早历史无入口

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：将有限历史窗口当成完整聊天记录，没有按 cursor 向前翻页；手写窄接口隐藏了上游协议字段。

影响与边界：同一课长期聊天超过 50 条 user/assistant 消息，刷新/重开后早期目标协商、反馈和出处无法在界面查看。磁盘记录没有因此删除。

验证/触发条件：60 条 append-origin 合成消息输入官方 DSH paginate，默认返回 50 条，first seq=10、hasMore=true。；应用既不读取 hasMore，也无 page/加载更早入口。

源码与证据：

packages/kit/src/client/chat.tsx:19-28 自定义 Frame 没有 hasMore/cursor，SessionRemote 没有 page。

packages/kit/src/client/chat.tsx:221-225 follow 未指定历史窗口，snapshot 只遍历 records。

.tools/dsh/node_modules/@deepseek-ai/dsh-api-session-controller/lib/index.js:1373-1374 固定版本默认 MAX_MESSAGES=50。

.tools/dsh/node_modules/@deepseek-ai/dsh-api-session-controller/lib/index.js:1506-1519 opening snapshot 分页后返回 records 与 hasMore。

建议方案：1. 保留完整上游 typed 协议；显示“加载更早”并用 throughSeq/beforeSeq 分页，保持滚动锚点。 2. 长期会话按页/虚拟化显示；同时处理 assistantStream opening baseline，避免重开时丢掉已生成的流片段。

验收条件：1. 至少 120 条消息会话能逐页回到第一条，刷新后历史仍可浏览且无重复。 2. 加载上一页不跳滚动位置，失败可重试。

验证方式：chat-repro.mjs 实际提取安装的官方 DSH paginate 并调用真实 isAppendSurfaceEvent；chat-result.json 返回 50/60。

FE-08 讲义/试题插图的 PDF 缓存永不释放，绕过项目已有的借用释放机制

优先级 P2 · 静态控制流/生命周期确认

问题与根因：Figure 另起永久 cache，生命周期与组件/标签无关，还与 Reader 的 document cache 重复。

影响与边界：长时间跨多本教材/题目浏览会保留越来越多 PDF document/worker 资源；关闭 tab 也不释放。会推高内存，未进行浏览器 heap 测量，不能声称已经发生崩溃。

验证/触发条件：浏览来自许多不同 sourceId 的插图，再关闭对应页面。；源码生命周期显示成功项持续留在 module Map；不存在可执行释放路径。

源码与证据：

packages/library/src/client/figure.tsx:13-29 模块级 Map 保存成功 PDFDocumentProxy Promise，只有失败时删除。

packages/library/src/client/figure.tsx:45-85 组件 cleanup 只取消 render，无 doc.destroy/release。

packages/library/src/client/documents.ts:5-35 阅读器已有按引用计数借用、最后使用 30 秒后 destroy 的共享实现。

建议方案：1. Figure 复用 borrowDocument 并在 cleanup 调用 release，必要时给共享缓存加字节/文档数上限。 2. 并行插图绘制设并发界限；全页临时 canvas 裁切的峰值内存另做测量后优化。

验收条件：1. 打开/关闭多本 PDF 插图后，超过释放宽限期 document/worker 数量回落。 2. 同一 PDF 同时在 Reader 和 Figure 只借用一次，常用切换不频繁重新下载。

FE-09 菜单和命令面板只有视觉高亮，焦点语义与模态键盘行为不完整

优先级 P2 · 静态审查及真实浏览器键盘复现

问题与根因：实现了鼠标与可见按键响应，但没有统一的复合控件焦点模型；aria-modal 只是声明，没有封闭焦点或背景 inert。

影响与边界：读屏无法可靠跟随箭头选择；Tab 可离开标为模态的面板，焦点到 option 后 Esc 处理不再来自输入；仅键盘用户不能调整侧栏宽度。

验证/触发条件：Ctrl+K 后用上下键：观察只有 data-active 改变，输入没有 aria-activedescendant。；在 Palette 中按 Tab 移入选项再 Esc，或继续 Tab 离开弹层；代码没有弹层级 Esc/focus 封闭。；打开共享菜单后检查 document.activeElement 与可访问性焦点。

源码与证据：

packages/kit/src/client/ui.tsx:169-206 菜单 show/move 只 setActive，未把焦点交给菜单项，也未建立 aria-activedescendant。

packages/kit/src/client/ui.tsx:226-228 菜单项 data-active 仅是 CSS 状态。

packages/shell/src/client.tsx:1467-1501 Palette 自动 focus 输入、仅输入处理 Esc/arrows；无 focus trap/restore，combobox 无 aria-activedescendant。

packages/shell/src/client.tsx:998-1020 可拖动 separator 无 tabIndex、键盘或 aria-valuenow/min/max。

建议方案：1. 菜单使用 roving tabindex+真实 focus 或 menu aria-activedescendant；稳定 option id。 2. Palette 实现模态 focus trap、恢复触发焦点、容器级 Esc、背景 inert；combobox 明确 active descendant。 3. separator 支持键盘增减和范围值，补同类 tab 语义与错误提示 live region。

验收条件：1. 真实浏览器键盘全流程与至少一种读屏核对；视觉 active 和读屏焦点相同。 2. Tab/Shift+Tab 在模态内循环，任意内部焦点 Esc 关闭并恢复焦点。

验证方式：实际 Chromium 连接本地 DSH 的 1440px 浅色空库中复现：ArrowDown 后焦点仍在 INPUT 且 aria-activedescendant=null；Tab 进入 option 再 Esc 面板仍打开；输入框 Shift+Tab 跳到背后“新建第一门课”；菜单 ArrowDown 后焦点仍在“外观”触发按钮而视觉 active 为“跟随系统”。原始结果 ui/report.json，截图 ui/palette-1440-light.png。未做屏幕阅读器实测，separator 仅静态检查。标准依据 W3C APG menu-button/dialog-modal/combobox。

FE-10 全局弱化文字色在常用背景上低于普通文字 4.5:1 对比度

优先级 P2 · 源码色值计算；非完整 WCAG 认证

问题与根因：设计规范把 text3 当作可用于正文的最浅文字，但 token 未按各主题/背景对比度校验。

影响与边界：重要页码、来源信息、说明的可读性受损。计算值浅色页 3.455:1、浅色 chrome3.219:1、深色页 4.246:1、深色 raised3.879:1；这些 12px 文本不适用大字 3:1 例外。

验证/触发条件：以源码 sRGB 颜色按 W3C 相对亮度公式计算，contrast-repro.mjs 输出 contrast.json。

源码与证据：

- packages/shell/src/shell.css:7-21 浅色背景#fff/#f7f7f4 与 text3=#8c8a83。
- packages/shell/src/shell.css:89-102 深色背景#1b1b1a/#232321 与 text3=#807e78。
- packages/shell/src/shell.css:1515-1520 资料元数据/检索头使用 text3 和 12px 字号。
- packages/shell/src/shell.css:1541-1560 页码、侧栏标题、出处路径使用 text3 和 12px。

建议方案：1. 调整文字专用色使实际所有常用底色达到 4.5:1，装饰 token 单独保留。 2. 给设计 tokens 加对比度校验，并结合深浅色、低视力/高对比场景实测。

验收条件：1. 所有信息性小字与实际背景至少 4.5:1；不将禁用/纯装饰项计入同一标准。

验证方式：源码色值计算，非截图感受；已读取 W3C WCAG22 Understanding SC1.4.3。未声称整个应用通过或不通过完整 WCAG 审计。

FE-11 不可编辑的原书段落进入编辑器后永久显示加载占位

优先级 P2 · 静态控制流/生命周期确认

问题与根因：把“尚未初始化 text”用作全部分支的加载条件，拒绝分支排在它之后。

影响与边界：用户选择原书引用点击修改，既无法编辑也看不到“不能改/可以批注”的解释和关闭按钮，只见永久加载。

验证/触发条件：给 blockSource 返回{refused:"这是原书原文…"}；初始 text=undefined，加载完成仍命中第 106 行。

源码与证据：

- packages/textbook/src/client.tsx:99-107 refused 响应没有 text，text 状态 undefined；106 先返回 Skeleton，107 拒绝说明不可达。
- packages/textbook/src/client.tsx:395-397 选区浮条对所有段落提供修改按钮。
- packages/textbook/src/index.ts:479-482 原书原文 block.original 明确返回 refused。

建议方案：1. 先分支处理 source.error/loading/refused，只有可编辑{text}再初始化草稿；保留显式关闭。

验收条件：1. original 与 block-missing 两种 refused 均显示原因和退出入口，没有 Skeleton 悬挂；正常块编辑不受影响。

AN-01 读取批注时的异步位置重算会覆盖并发保存的新内容，甚至恢复刚删除的批注

优先级 P1 · 局部运行复现；非完整业务 UI 验收

问题与根因：查询路径持有旧对象跨越 await，随后回写完整数据；没有只更新 location 或并发版本检查。

影响与边界：后台刷新与用户编辑/隐藏同时发生且原文位置改变时，已确认保存的新批注被旧文本覆盖，hiddenAt 也可被抹除，界面删除的批注重新出现。读取产生数据丢失。

验证/触发条件：创建旧批注，改正文使定位从 anchored 变为 needs-confirmation。；启动 list 并在 learnTextbook.block 的 await 处暂停；此时 edit 为新文字并 hide=true。；释放 list：持久化 text 回到旧批注，hidden=false。

源码与证据：

- packages/annotation/src/index.ts:230-240 list 读取整条 annotation 后 await place，位置变更时把旧 annotation 整条 save。
- packages/annotation/src/index.ts:91-92 save 覆盖 data 整列。
- packages/annotation/src/index.ts:251-271 edit/hide 同步修改同一 data；没有 revision/CAS。

建议方案：1. 定位结果仅通过 SQL JSON 路径或重读最新记录后合并 location；用户字段不可由读取覆盖。 2. 若定位取决于已改字段，使用版本/CAS 重算并重试；位置派生缓存可考虑只读计算不落盘。 3. 同类跨 await 全记录 save（如 submitError）一起检查。

验收条件：1. 用屏障注入并发：list 期间 edit/hide/resolve/linkSideChat 完成后，所有用户字段保持最新值。 2. 位置仍能更新，不发无限刷新事件。

验证方式：annotation-audit.test.ts 使用本仓库真实业务服务、实际 SQLite/文件与 harness 假 DSH；3 项定向特征测试之一已通过，结果 annotation-result.json 中明确 new→old、hidden true→false。

AN-02 报错批注的并发提交可创建两个提案，只保留最后一个关联

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：幂等检查发生在异步操作之前，事务只包创建写入，没有把“是否已存在”判定与创建原子化。

影响与边界：同一批注出现重复教师核对任务/重复 handoff，早创建的提案没有批注关联，处理状态可能与界面脱节。单个按钮 busy 不能保证多标签/重试/多个调用方幂等。

验证/触发条件：先创建位置不确定的 error 批注，避免自动创建 proposal；正文改成唯一可定位。；同时 Promise.all 调用两次 submitError；实际返回不同 ID，提案总数 2，批注只指向第二个。

源码与证据：

packages/annotation/src/index.ts:396-417 先读取 annotation.proposalId，再经过两次 await，事务中未重读/唯一约束即创建 proposal 并覆盖关联。

packages/annotation/src/index.ts:427-438 ask 有并发共享 Map，而 submitError 没有相同的保护。

建议方案：1. 在事务内重读最新 proposalId，再 create 并关联；为 annotation→proposal 增加唯一约束或稳定幂等 key。 2. 进程内共享 Promise 只做优化，数据库约束承担最后保证；关联时合并最新用户字段。

验收条件：1. 同一批注并发 10 次/响应丢失后重试，只产生一个 proposal 和一次 handoff，所有成功调用返回同一 ID。

验证方式：annotation-audit.test.ts 真实服务+SQLite 确认 2 条 proposal，annotation-result.json 记录不同 ID；无真模型。

AN-03 段首新增否定词后批注仍被自动认定为原句，保守锚定规则失效

优先级 P2 · 局部运行复现；非完整业务 UI 验收

问题与根因：空上下文同时表示原文边界和缺少上下文，定位算法把它统一当作无需检查。

影响与边界：原句“能忽略摩擦损失。”变为“不能忽略摩擦损失。”时，原批注仍 anchored，误导用户以为旧理解或重点仍适用于当前结论；违背宁可确认也不挂错的产品原则。

验证/触发条件：locateQuote("能忽略摩擦损失。", {exact:"能忽略摩擦损失",prefix:"",suffix:"。"}) → anchored/start0。；改为“不能忽略摩擦损失。”同一 selector → anchored/start1；预期 needs-confirmation。

源码与证据：

packages/annotation/src/anchor.ts:122-128 唯一匹配时只有 prefix 非空才检查左邻字符，空 prefix 没有保护原段首边界。

packages/annotation/test/anchor.test.ts:43-50 已有否定测试只覆盖非空 prefix 的“这里不能忽略”，漏掉段首。

建议方案：1. 选择器明确记录起止边界/创建时上下文完整性；段落 hash 变更后检查边界新增的语义字符。 2. 在无法区分缺少上下文与段首时，保守进入确认；不要仅凭原句是新句子子串就自动迁移。

验收条件：1. 段首加不/非、段尾续写条件、公式符号变化及重复句场景均不会未经确认自动挂到改变含义的句子。

验证方式：annotation-audit.test.ts 直接调用真实 anchor 函数，annotation-result.json 记录 start0→start1 仍 anchored。

八、工程交付与成熟度建设

ENG-01 仓库内未配置持续集成门禁，自动验收缺少真实 DSH 与 React 交互

优先级 P2 · 静态盘点与工程成熟度建议

问题与根因：已有测试对业务规则投入充足，但边界替身承担了最容易漂移的运行时协议；仓库没有 tracked .github/workflows 等自动门禁。

影响与边界：全量单测通过不能证明安装、插件实际注入、流重连、菜单焦点、草稿时序正确；本次发现的多项 UI/DSH 协议问题位于此盲区。不能据此否定现有测试的业务价值。

验证/触发条件：git ls-files 检查无.github/workflows；测试目录 67 个.test.ts 文件，没有 tracked 真实 React/browser interaction suite。；对比 harness 直接 apply 与 packages/app 真实 profile 加载路径。

源码与证据：

- tests/harness.ts:100-170 传输/会话/模型均使用假实现。
- tests/harness.ts:173-186 直接依次调用各 unit.apply，绕开真实 plugin loader/inject/exports/组合包装配。
- tests/harness.ts:188-212 调用 route.fetch 而非实际 HTTP/auth/stream 载体。
- vitest.config.ts:14-23 只列入.test.ts，已有测试主要服务/纯函数，未见真实 React 交互/端到端 suite。
- docs/development.md:43-58 当前流程为手动 typecheck/test/build 与截图脚本。

建议方案：1. 加入最小可复现 CI：固定 Node/pnpm，frozen 安装、typecheck、tests、build。 2. 另起合成数据+假模型的真实 DSH smoke，校验插件状态/页面接口/聊天流；保持付费网络默认禁止。 3. 增加高风险浏览器场景：课程切换、保存失败/乱序、断线重连、50+消息、键盘模态和后台 tab 标题。

验收条件：1. 干净 runner 一条命令自动执行门禁并产出报告；故意破坏 inject 或 UI 状态机时相关门禁确实失败。 2. 不要求为了覆盖率而给每个样式或简单 getter 写镜像测试。

验证方式：跟踪文件盘点和测试调用链静态审查；构建、类型检查与全套测试的实际结果见本报告第二节。

ENG-02 DSH 仅锁顶层版本和发布时间上限，运行时依赖图与工具版本尚未完整固定

优先级 P2 · 静态盘点与工程成熟度建议

问题与根因：源码 pnpm-lock 与外部 DSH npm 依赖图分离，后者的锁文件不随仓库保存；未验证实际兼容的完整 runtime graph 或工具小版本。

影响与边界：不同机器/历史安装可能拥有相同 DSH 版本但不同传递依赖，出现类型、插件或运行时差异。--before 是有价值的缓解，不等同版本+integrity 完整锁定；本次未证明任意 fresh install 必然不同。

验证/触发条件：setup 脚本只比较 require(dsh/package.json).version；传递依赖被改动时仍会打印 already installed。；git tracked 中没有用于.tools/dsh 的锁文件；生成锁只存在机器本地。

源码与证据：

scripts/setup-dsh.sh:7-21 用--before 规避已知不兼容发布，npm install 解析到被忽略的.tools/dsh；已有安装只检查 DSH 顶层 version。

README.md:34-43 文档要求 Node24/pnpm11，但安装命令不是 frozen 默认说明。

package.json:1-27 无 engines/packageManager 字段。

建议方案：1. 把 runtime 依赖 manifest/lock 作为受版本控制的 bootstrap 资产，用 npm ci 与 hash 校验安装到.tools/dsh。 2. packageManager 固定受支持 pnpm 版本，engines 声明 Node；记录 Windows/Git Bash/Chrome 支持边界。 3. 依赖更新用独立兼容性变更，跑真实 DSH smoke。

验收条件：1. 在相同受支持平台和固定工具链上，两台干净环境得到一致 DSH 依赖清单与 integrity；跨平台可选依赖差异有明确说明；既有不匹配安装被检测。 2. README 从无 key 新克隆可完成离线/假服务开发验证，真实模型验收另列。

ENG-03 公开仓库缺少明确许可证和基本维护入口

优先级 P3 · 静态盘点与工程成熟度建议

问题与根因：个人早期项目重视交接给助手的规则，但对外部读者的使用许可、问题提报与维护责任没有同等明确说明。

影响与边界：协作与复用预期不清，安全问题没有约定私下反馈入口；不是本地运行功能故障，也不因未发布 npm/没有公网服务而扣分。

验证/触发条件：git ls-files 盘点许可证及维护文件为空；README 无对应章节。

源码与证据：

README.md:1-9 项目与开发链接齐备，但无许可证/维护入口说明。

package.json:1-27 private=true，未声明 license；tracked 文件盘点未发现 LICENSE/SECURITY/CONTRIBUTING/CODEOWNERS/CHANGELOG。

建议方案：1. 由作者明确代码是否允许开放复用并选定许可证；助手不擅自替作者选择。 2. 简短 CONTRIBUTING 和 SECURITY 说明开发入口、复现材料、报告渠道；CHANGELOG/版本策略在实际发布前建立。

验收条件：1. README 可直接找到作者明确的许可决定和问题反馈路径；说明当前仅本地单用户的支持范围。

M01 备份、恢复与跨载体一致快照

源码已有文件变更历史、SQLite 迁移和单项回退，但未形成可演练的完整备份恢复入口。学习数据跨 LEARNING_HOME 的数据库/Markdown/原件，以及 DSH 会话与附件；只复制当前 Markdown 不足以恢复课程，运行中只复制单个数据库文件也不应被当成可靠快照。建议先提供停写或协调快照的离线备份方案、文件清单和 hash、版本信息、恢复到新目录的演练。凭据应单独处理，由用户明确是否纳入加密备份。

依据：docs/core/design.md；packages/core/src/db.ts:16-44；packages/settings/src/client.tsx；SQLite 官方备份 API

最低验收不是“压缩包成功生成”，而是在干净目录恢复课程、原始 PDF、题目版本、会话引用和证据，然后重算后得到同一结论。对 DATA-01 的发布协议先定义崩溃恢复，再定义一致备份；二者应共享数据清单。建议在放入大量个人笔记前完成一次恢复演练。

M02 迁移、升级与降级保护

按单元编号的迁移和事务已存在，不应报为没有迁移能力。缺的是旧库样本矩阵、升级前备份、失败恢复与新旧程序兼容策略。当前 migrate 按最高版本跳过已执行步骤；可补 migration 校验和、遇到比程序新的 schema 拒绝启动、关键旧版本 fixture，以及不可逆升级提示。这里提出工程保障，没有模拟生产旧库损坏。

依据：packages/core/src/db.ts:31-46；docs/trial.md

M03 帮助记账失败不能等价于没有帮助

tutor 记录器分类连续失败后推进游标，sidechat 会保存 skipped 段；两者还会截断较长消息用于分类。成功补记迟到 help 后 learner 确实会重算，已经通过反例验证，因此“迟到帮助永远错判”不成立。但失败后自动流程不再分类该窗口（原始消息仍在），尚未分类的窗口也应显式成为 evidence-gap/pending，而不能默认为独立。gap 表示帮助状态未知，不表示已经确认发生帮助，也不应否定更

早的有效独立证据。建议保存待修复区间、错误类别和模型版本，提供重试与人工校正；在涉及正式验收的区间未处理完前，使用“帮助状态未确定”。

依据：packages/tutor/src/ledger.ts:134-150；packages/sidechat/src/ledger.ts:170-186；packages/learner/src/rules.ts

M04 可靠事件与启动对账

当前 afterCommit 避免在数据库回滚前发事件，这是正确基础；内存回调仍不等于持久化投递。对于会推进阶段、发布讲义、刷新掌握或交回主老师的关键事件，应选择可重放 outbox 或启动对账，消费方做幂等。普通界面刷新可以简单在 SSE 重连后全部失效重取，无需为个人应用建设复杂消息平台。事件只承载提示，核心状态必须能从持久化事实重建。

依据：packages/core/src/db.ts:49-77；packages/core/src/index.ts:115-143；packages/textbook/src/index.ts；packages/curriculum/src/index.ts

M05 AI 质量、提示词版本与可重复评估

现有测试大量使用假模型，能够验证解析、流程和错误处理，无法给真实模型判分准确率或教材正确率背书。建议从一小套人工核对的化工题开始，固定原题、答案依据、允许误差、单位、变量域、rubric 和不可判定条件；记录模型路由、实际版本、提示词 hash、来源版本、输入输出、规则版本和复核结论。模型升级、模板变化和来源解析升级都跑相同集合，并将“错误被确定判对”作为单独指标。

帮助分类、知识抽取、讲义引用、手写双识别也要有各自任务集。判分器离线验收可以使用正式题，但评估时向学习者展示过的题干/答案必须记为曝光，不能再作为其新题证据；用于模型选择的集合与最终验收集合也应分开。对教育有效性的判断应看独立新题、延迟保持与人工复核负担，而非生成速度或聊天轮数。本轮没有测出这些准确率，不提供虚构的百分比。

M06 外部服务、任务成本与模型边界

共享 complete 已有限次重试、输出上限、按 purpose 记录耗时/usage，DSH 也有模型空闲超时；不能说项目完全没有超时或计量。仍建议补整个任务的 deadline、取消、跨模块全局并发上限和费用/令牌预算，把重试消耗也算入同一任务。每次运行保存实际解析后的模型及服务配置版本，避免默认模型变化后缓存来源不清。预算以供应商实际返回 usage 为准，缺失时注明估算。

依据：packages/kit/src/index.ts:168-245；packages/textbook/src/index.ts

对外部资料和模型输出，坚持“内容只能提供候选事实，不能自授权限/来源等级/答案权威性”。提示注入不应只靠一句 system 提示处理：工具参数必须经过领域不变量校验，来源文本与操作指令分开，模型产生的 URL/HTML/公式走各自边界。没有给老师开放通用 shell 是已有有效防护，应保留。

依据：packages/assess/src/tools.ts；packages/app/cordis.patch.yml

M07 性能、容量与长期资源生命周期

本次构建的 12 份客户端 JS 产物合计 6,733,028 字节，分别 gzip level 9 后合计 1,449,319 字节；shell 约 2.45MB 原始、646KB gzip，library 约 1.22MB 原始、245KB gzip。该测量是构建产物大小，不是浏览器实际传输、首屏时间或缓存命中结果。buildClient 没有开启 JS minify；CSS/KaTeX woff2 字体会内联，React 和 DSH 保持 external。先测真实加载，再决定压缩、重型 PDF/图模块延迟加载与共享资源方案。

依据：scripts/build.mjs:1-108

长期规模应测三类指标：大 PDF 解析/插图渲染的内存峰值，多课程知识图与日志重放的耗时，长会话/长讲义的 DOM 与交互延迟。同步 SQLite/文件访问和全量重放是否需要优化取决于真实规模，不能只看同步 API 就宣布性能故障。已确认的 Figure PDF 缓存在页面生命周期内不释放（FE-08）可以先修；其余用固定合成规模和同一设备记录 p50/p95、内存高水位与取消耗时，再制定预算。

M08 类型、协议和可维护性

不建议按行数机械拆文件。应围绕提交、版本、有效证据、发布协议等高风险职责提取纯函数和领域服务，让调用路径少解释一次同样事实。当前手写窄 SessionRemote 协议遗漏 DSH 历史分页字段，说明类型断言与自定义协议适配应集中在少数边界，并有真实运行时契约测试。对 RPC 请求/响应可从共享 schema 生成或统一声明；每个工具、页面和恢复路径必须经过同一领域校验。

依据：packages/kit/src/client/chat.tsx:19-28；docs/contracts.md；packages/assess/src/store.ts

M09 数据出口、保留期与隐私说明

已有数据位置展示、外发说明和密钥不回显的设计，值得保留。进一步应明确每种服务收到什么：模型的教材片段/作答照片、嵌入的资料文本、搜索查询、云解析的原 PDF；关闭开关影响未来请求还是正在执行的任务；删除本地资料是否影响历史证据与远端任务。课程归档、完整导出、照片/会话保留期和安全删除应有一致说明，避免“只在本地运行”被理解为内容从不外发。

依据：docs/trial.md:5-15；packages/settings/src/client.tsx；packages/library/src/retrieval.ts

教材和网页来源应保留版权/授权元数据与引用位置。个人学习、公开分享讲义、发布含原文的数据集的边界不同；当前不需要引入大型合规平台，但未来开放共享前必须明确授权及删除策略。本报告没有提供法律合规认证，也未访问用户真实教材。

M10 错误可观测性和本地诊断

已有日志、任务状态和 learning-perf 是基础。建议将 courseId、runId、submissionId、sessionId、provider 与错误码串成一条本地诊断链；界面区分可重试、需配置、输入冲突和不可判定。导出诊断包默认去除密钥、签名 URL、教材全文和照片，只保留用户选择的片段。监测关注挂起任务、重复事件、未保存草稿、证据重放失败和预算耗尽，不必默认部署外部遥测。

依据：packages/kit/src/index.ts；packages/core/src/index.ts；packages/textbook/src/index.ts

M11 支持矩阵、移动端与无障碍验收

当前说明同时涉及 Node24/pnpm11、Git Bash、Windows 脚本和 Chrome，本轮实测只覆盖 Linux/Chromium 与手机视口模拟。建议在 README 列出已支持、试验和未验证组合，并在真实 Windows 上验证安装、文件占用/替换、中文路径和备份恢复；未来扩大为真手机接入时，再在至少一台真实手机检查软键盘、选区、照片上传、横竖屏和安全区；键盘与读屏从共享控件到完整答题流程验收。手机布局刚引入；当前设计明确 DSH 只监听本机、未交付真手机/LAN 访问，不能把这个范围外能力报为现阶段缺陷，也不应把模拟器空库成功当作完整移动支持。

依据：README.md:34-43；scripts/setup-dsh.sh；scripts/mineru-server.ps1；docs/trial.md

M12 文档、协作与发布治理

设计文档和用户原话记录很丰富，适合维护者及 AI 协作者接手；建议再补一份只面向新使用者的最短安装/配置/备份/恢复路径，以及一份面向贡献者的自动验收入口。对过期 PR、冻结历史和当前设计建立明确状态，减少“文档有功能、主分支是否已具备”的歧义。发布前再建立版本标签、变更日志和升级说明；许可证由作者决定，助手不替作者选择。公开 GitHub 仓库本身并不自动授予开源许可证。

依据：README.md；docs/development.md；docs/PLAN.md；GitHub 许可证说明

九、建议修复顺序与退出条件

以下按依赖和风险排序，不编造开发工期。在 A/B 批开始之前，先完成 M01 的最小一致快照与恢复演练；特别是变更持久化模型或迁移旧数据之前，必须已有可用回退点。小修可以并行，涉及数据模型的变更应先定契约和迁移。每一批只要满足退出条件就继续交付，不以覆盖率数字或功能数量代替验收。所有建议均保持当前本地单用户架构。

批次	具体工作与对应项	退出条件
A 输入与保存边界	SEC-01/03/04；FE-01/02；DATA-02/03；AN-01；DATA-05。先把 HTML 净化、求值白名单/隔离、外发取消、草稿 ACK、资源身份和版本条件收紧。	外部内容不执行代码；关闭后无新外发批次；失败不丢输入；过期编辑/恢复不覆盖；事务开启失败后可恢复。
B 提交和事实版本	L01/02/05/09/10/11、AI-01、DATA-01。引入 Submission/ProblemVersion、完整数字解析、来源凭据、文件发布恢复协议。	同次提交仅一组证据；中断后不重复；题目/答案/提交时刻不可变；来源可信可检查；文件与 DB 可对账。
C 统一验收链	L03/04/07/08/12/13/15/16/17、M03。统一 effectiveEvidence，状态联合类型，复盘和目标版本依赖，曝光与计时语义。	改判/撤证/帮助/目标变更使旧结论失效；不同选题方式能完整走完；不确定判分不会变成肯定掌握。
D 身份、恢复与交互	SEC-02/06/07；L06/14；DATA-04；FE-03 至 11；AN-02/03。补提交时去重、规范身份、重连、历史分页、缓存释放和键盘。	切换/重试/重连都收敛到同一事实；长会话可查；关闭文档释放资源；键盘能完成主要流程。
E 稳定交付与真实评估	SEC-05、ENG-01/02/03 和 M01 至 M12。锁运行时、CI、备份恢复、迁移、真实 DSH 回归、人工题集和成本预算。	干净机器可重复安装；真实流程回归通过；旧数据可恢复；模型升级有可比较证据；对外支持范围明确。

需要先共同设计的四个接口

第一，提交接口：提交时一次冻结答案、问题版本、确认状态、时间与 submissionId；短事务占有提交，异步判分，逐题唯一键恢复。不要跨模型等待持有 SQLite 事务。引入 submitted 状态时同时修正答案可见性，避免当前“非 open 就返回答案”造成新泄露。

第二，有效证据接口：返回原始评分、当前有效评分、撤证/待定原因、帮助、新颖性和依赖版本。learner、阶段报告、复盘、结课报告读取同一投影；历史原始成绩保留，当前结论可以失效且解释原因。

第三，修订接口：目标、设计、段落和批注的命令带 expectedRevision 或内容 hash；同一版本只允许一次成功更新；失败返回可合并冲突而非吞掉输入。稳定身份不等于稳定语义，目标 canDo key 保留时仍应产生新语义版本。

第四，任务接口：保存 owner/provider identity、baseVersion、取消状态、重试计数、整体 deadline 和输出版本；恢复沿用原基准，配置切换只影响新任务，或明确迁移在途任务。外发停止和远端取消失败分别显示。

面向下一次个人试用的最低门槛

至少确保一份答卷只算一次、最后一版作答不丢、当前笔记不被旧后台动作覆盖、原始题目与答案可追溯、失效证据不支持“通过”、外部 HTML 和表达式受限、完整数据能恢复。达到这些门槛后再用少量真实章节试用，同时人工核查关键答案和阶段建议。可以先缩小功能范围，避免在不稳的事实层上扩展更多模型角色或题型。

十、验证计划与验收用例设计

按风险分层，而非只提高覆盖率

层次	最应覆盖的内容	运行方式
纯规则	数字完整消费、单位/域、有效证据、撤证、时间、身份归一、anchor 边界。	确定性小样本；包含相似但不相等的反例和边界值。
真实服务与存储	并发提交、两份旧视图、改判后决策、任务取消/恢复、数据库失败。	复用现有 harness 的真实 SQLite/文件，假模型与屏障控制时序。
真实 DSH 装配	插件注入、exports、profile、认证路由、协议版本、会话 snapshot/stream/page。	隔离合成数据与假模型端点；不默认触达付费服务。
浏览器交互	离线/乱序保存、切课、后台标题、长历史、重连、键盘、移动输入。	自动化浏览器结合少量真实设备与读屏检查。
模型与教学	判分误报正确、来源一致、帮助识别、手写识别、独立新题/延迟表现。	人工标注黄金集、盲评与真实试用；费用预算和版本记录。
恢复与交付	旧库升级、完整备份恢复、失败点注入、两机安装依赖一致。	干净目录/runner，恢复后做业务对账和证据重算。

八条建议写成跨模块回归的不变量

1. 一张提交中的一个问题版本最多有一条原始作答事实；任意网络重试、并发和重启都不改变这个上限。

2. 用户收到保存成功后，未获其明确选择的旧客户端、后台恢复或只读刷新不能把现版改回旧值。

3. 任意被撤证的作答不再支撑当前掌握、阶段通过、复盘建议或结课结论，但历史事实与撤证原因可查。

4. 目标语义、试题版本或验收映射变化后，旧报告必须显示过期；用户确认必须引用当前依赖版本。

5. 无法证明的来源/等价/单位不能被程序提升为确定权威或确定正确；保留明确的不确定状态。

6. 新课程作用域只允许操作本课资源；新资源加载失败不能继续使用旧资源执行写入。

7. 停止外发后不得启动新批次；取消与恢复必须作用于任务原本所属服务，错误要可见。

8. 文件、数据库、派生索引和关键事件经历任一故障后，都能在重启或重连后对账收敛；正常读取不修改用户事实。

模型评估的最小可用样本设计

先由熟悉化工原理的人核对一小批真实题，不需要一开始追求大数据集。按量纲、百分数、科学计数法、有效数字、符号域、图表读取、多问部分错误、开放题 rubric 和错误答案解析分层。每题保存标准答案来源及可接受变体，另造容易误判的近邻错误答案；这些错误答案用于测试判分器，不进入教学材料。

评估至少分开报告：正确答案被拒、错误答案被确定接受、进入待复核的比例、人工复核耗时、不可用服务下恢复率和单次费用。总体正确率会掩盖最危险的“错误却判对”。当一个模型替换另一个时，在固定输入和规则版本上比较；不要用模型自己的置信度当成已校准置信度。

学习效果另设观察：同一个人独立完成新题、间隔后再做不同题、能否解释适用条件、有没有因错误报告提前跳过学习。由于当前为个人使用，结果可先做个体纵向记录，不声称具有普遍教育研究效力。

避免无价值的验收负担

不要求每条 CSS 都配快照测试，不要求每个 getter 镜像一遍实现，也不要求每次提交都调用真实模型。将本文定向反例转成稳定、能失败的回归；将少量真实 DSH 和浏览器流程放进交付门禁；付费模型评估按相关变更或明确预算运行。修复完成后删除只证明旧缺陷现象的审计断言，改成对正确行为的验收。

附录：问题索引、证据与复核说明

编号	级别	问题
DATA-01	P1	文件替换与 SQLite 提交不具备真正的跨资源原子性
DATA-02	P1	恢复讲义生成时重新取基准版本 会覆盖停机期间的外部编辑
DATA-03	P1	段落编辑接口没有携带打开编辑器时的版本
AI-01	P1	讲义公式比对删掉上下标符号 会漏掉改变数学含义的错误
AI-02	P2	事实段落缺引用时，没有主动标识来源缺口
DATA-04	P2	讲义重新索引只新增知识关联 不移除已经失效的关联
DATA-05	P2	BEGIN 失败会使连接一直处于错误的嵌套事务状态
SEC-01	P1	共享 Markdown 渲染器未净化不可信 HTML，存在存储型 XSS
SEC-02	P1	跨域重定向绕过资料网站分级并错误保留权威出处
SEC-03	P1	关闭语义检索后当前资料仍继续上传后续批次
SEC-04	P1	表达式判分执行完整 mathjs 语言而未采用受限计算器边界
SEC-05	P2	开发依赖和独立 DSH 运行时存在已公开漏洞且缺少联合升级门禁
SEC-06	P2	MinerU 请求重定向递归无上限且每跳重置超时
SEC-07	P2	切换解析服务后取消与恢复使用错误的任务所属服务
L01	P1	交卷缺少持久化的提交锁与幂等键，同卷并发或中断重试会重复写入作答证据
L02	P1	模型可仅靠 authority/tier 标签把无出处原创题放入测试预留池
L03	P1	题目被纠错后，旧作答已在掌握层作废，却仍能让阶段复盘判为通过
L04	P1	显式指定阶段/结课题目会绕开必需蓝图，生成无法完成正常复盘的测试
L05	P1	表达式“等价”只在 0.5–2 的随机正数上抽样，非恒等式被确定判对
L06	P2	并行小节抽取以过期图快照去重，正常抽取会制造同名歧义节点
L07	P2	学习中的阶段可以直接重写设计并清除确认，但再也无法确认新设计
L08	P2	撤回测试会暴露参考答案，却不将预留题记为已见，之后仍当新题组卷
L09	P2	题目原地可变但作答未保存题目版本，历史试卷会换成新参考答案

编号	级别	问题
L10	P2	目标版本检查不是原子比较并交换，同版本并发修订均成功且丢失内容
L11	P1	数值判分只取数字前缀，维度未知时无条件忽略尾部内容
L12	P2	诊断把所有“部分对”当作已会，多问题一问全错也会跳过先修探测
L13	P2	模型判分耗时被算作学习者超时和作答时长
L14	P2	知识身份合并后阶段仍引用旧身份，正常自动组卷找不到当前节点的新题
L15	P1	保存复盘后改判不会使待决定的复盘失效，失败可以沿旧通过结果无风险推进
L16	P2	结课测试换题不更新目标条目的问题引用，替补题答对仍被算作没答
L17	P1	结课检验没有绑定目标语义版本，旧测试可为大幅修订后的目标背书
FE-01	P1	作答自动保存会吞掉失败、提前清除脏状态，交卷也不等待已发出的保存请求
FE-02	P1	切换课程时侧边会话仍可操作上一门课；新课程加载失败后可无限保留旧会话
FE-03	P2	后台页面异步补全标题会抢走正在操作的标签页
FE-04	P2	学习变更 SSE 重连只恢复连接灯，断线期间的数据变更不会补同步
FE-05	P2	useLoad 的空 refreshOn 数组实际订阅了所有事件
FE-06	P2	聊天流中断后不会重新订阅；再次发送成功会清掉错误但无法收到回复
FE-07	P2	聊天只显示 DSH 默认最近 50 条消息，重开后更早历史无入口
FE-08	P2	讲义/试题插图的 PDF 缓存永不释放，绕过项目已有的借用释放机制
FE-09	P2	菜单和命令面板只有视觉高亮，焦点语义与模态键盘行为不完整
FE-10	P2	全局弱化文字色在常用背景上低于普通文字 4.5:1 对比度
FE-11	P2	不可编辑的原书段落进入编辑器后永久显示加载占位
AN-01	P1	读取批注时的异步位置重算会覆盖并发保存的新内容，甚至恢复刚删除的批注
AN-02	P2	报错批注的并发提交可创建两个提案，只保留最后一个关联
AN-03	P2	段首新增否定词后批注仍被自动认定为原句，保守锚定规则失效
ENG-01	P2	仓库内未配置持续集成门禁，自动验收缺少真实 DSH 与 React 交互
ENG-02	P2	DSH 仅锁顶层版本和发布时间上限，运行时依赖图与工具版本尚未完整固定
ENG-03	P3	公开仓库缺少明确许可证和基本维护入口

证据包的使用

随报告提供的技术证据包含 48 项机器可读问题、CSV 清单、外置反例脚本、最终运行摘要、依赖扫描、覆盖率摘要和真实 UI 检查的文字结果。没有包含用户数据、运行时凭据、浏览器认证 URL、浏览器二进制、依赖目录或 UI 截图。报告中的源码链接固定到审查提交；.tools/dsh 下的证据属于按脚本安装的上游运行时，不是仓库跟踪源码。

复现应在独立克隆、固定提交及隔离临时数据中运行。部分脚本从本次提交中提取函数来验证时序，故意依赖其源码结构；它们适合解释现有缺陷，不能直接当成稳定的长期测试。fault injection、假 embedder/解析器、hook 桩和浏览器 sink 分别在用例中注明。不要把脚本放到真实学习库运行。

推荐目录布局：同一父目录下放 learning-agent 固定提交克隆，以及从证据包解出的 audit 目录。先在该父目录运行 python3 configure_paths.py，再进入仓库执行下面的命令。证据包附有路径配置说明；原始脚本中的本次绝对路径已在交付副本中替换为可配置的审查根目录。

```
git checkout cb62c7aef96be1f15b5206bf2dc600c2cb636d85
pnpm install --frozen-lockfile
sh scripts/setup-dsh.sh
pnpm build
pnpm typecheck
pnpm test
pnpm coverage
pnpm exec vitest run --config ../audit/root/vitest.config.mts
pnpm exec vitest run --config ../audit/learning/vitest.config.mjs
pnpm exec vitest run --config ../audit/frontend/vitest-audit.config.mjs
```

上述命令在仓库目录执行；浏览器证据需要自行配置 Chromium 可执行文件，服务器类测试需要允许回环监听。证据包 README 列出各脚本要求；本报告没有附带依赖或浏览器安装包。

关键原始记录

文件/目录（证据包内）	内容
findings.json / findings.csv	统一编号、严重度、影响、源码位置、修复和验收；保留验证方式。

文件/目录（证据包内）	内容
root/tests-unrestricted.log、coverage-summary.json	427 通过/2 跳过的最终运行与覆盖率；最初环境监听失败不作为项目缺陷。
learning/domain-repro.test.ts、repro-output.txt	学习域 20 条反例与最终日志。
root/data-and-textbook.test.ts、repro.log	核心文件和讲义 6 条反例。
learning/begin-failure-repro.mjs、begin-failure-output.txt	新增 BEGIN 失败后回滚和事件失真的隔离复现。
frontend/*-repro、*-result、ui-report.json	草稿/切课/聊天/标题/对比度/批注反例与真实浏览器文字结果。
security/repro-*	净化边界、mathjs 副作用、来源跳转、关闭嵌入和解析器切换复现。
security/pnpm-audit.json、dsh-npm-audit.json	两套依赖树的当日完整扫描，须按可达性解释。
root/repository-metadata.json、open-pr.json	公开仓库与现有开放 PR 的只读快照。

主要外部依据

外部文档只用于解释渲染器责任、表达式风险、无障碍、备份及许可/公告边界；项目缺陷结论主要来自固定源码与本次复现。没有引用二手文章替代项目事实。

Marked 安全说明：Marked 本身不净化输出 HTML；用于 SEC-01 的渲染边界解释。

mathjs 表达式安全说明：限制有副作用函数与资源使用；用于 SEC-04，不表示已证明系统逃逸。

W3C WCAG 2.2 对比度说明：普通文字 4.5:1、大字 3:1，适用例外需分开。

WAI-ARIA 组合框模式：焦点、active descendant 和键盘交互参考。

SQLite 备份 API：一致数据库快照的官方机制；整个学习库仍需跨载体协调。

GitHub 许可证说明：公开仓库与开源许可的区别。

Zod GHSA-mrhx-c7xc-m3w5：审查日确认受影响<4.6.6 及资源耗尽公告。

KaTeX GHSA-238p-pmpm-9mq7：受影响<0.18.2，要求既存原型污染；不与 SEC-01 混为一项。

完成标准与保留意见

本轮完成了源码、文档、安装、构建、类型、现有测试、覆盖率、定向反例、独立运行时依赖与空库真实浏览器审查，并进行交叉审稿。没有修改项目以隐藏问题或让测试通过。报告将已复现行为、静态推导和成熟度建议分开，保留了所有会改变结论的限制。